Dossier de conformité cybersécurité d'une plateforme de téléconsultation

Étude de cas **fictive** en gouvernance, risques et conformité (GRC) appliquée à la e-santé en France : analyse de risques EBIOS Risk Manager, AIPD, déclaration d'applicabilité ISO 27001:2022, matrices d'écarts HDS et NIS2, plan d'actions et PSSI.

> **Avertissement.** Télémédix SAS, ses clients et ses fournisseurs sont inventés. Ce travail est un exercice de formation : il ne constitue ni un audit ni un avis juridique. État du droit arrêté au 11 novembre 2026.

Le cas en bref

Organisme	Télémédix SAS, éditeur SaaS de téléconsultation, 52 salariés
Volumétrie	150 000 patients, 2 000 professionnels de santé, 30 000 téléconsultations par mois
Hébergement	Hébergeur certifié HDS (France) ; l'éditeur administre lui-même ses machines virtuelles
Sous-traitants	Visio, paiement, notifications

Résultats clés

Livrable	Résultat
Analyse de risques	10 risques, dont 6 élevés ; après traitement : 8 moyens, 2 faibles, aucun élevé
AIPD	Obligatoire ; gravité maximale pour l'accès illégitime ; avis du DPO favorable sous réserve
Déclaration d'applicabilité	93 mesures : 89 retenues, 4 exclues ; 10 en place, 60 partielles, 19 à faire
HDS	Hébergeur conforme ; **éditeur non certifié pour l'activité 5** (administration et exploitation) : 7 écarts majeurs
NIS2	Directive non transposée en France à la date du dossier ; qualification la plus probable : **entité importante** ; 7 écarts majeurs sur 13 exigences
Plan d'actions	28 actions sur 18 mois : 17 gains rapides, 7 projets structurants, 4 compléments

Contenu

Fichier	Contenu
01-cadrage.md	Périmètre, acteurs, flux, données, cadre réglementaire, état initial, hypothèses
02-ebios-rm.md	Ateliers 1 à 5 : valeurs métier, sources de risque, écosystème, scénarios, traitement
03-aipd-registre.md	AIPD (base légale, minimisation, durées, risques) et registres des traitements
04-dda-iso27001.md	Déclaration d'applicabilité : 93 mesures de l'Annexe A justifiées par les risques
05-ecarts-hds-nis2.md	Argumentation d'applicabilité et matrices d'écarts HDS et NIS2
06-plan-actions.md	28 actions priorisées (impact, effort), feuille de route
07-pssi.md	Politique de sécurité en deux pages
annexes/sources-et-points-a-verifier.md	Niveau de confiance de chaque affirmation et sources
pdf/dossier-complet.pdf	Export PDF de l'ensemble

Fil conducteur : la traçabilité

Chaque élément renvoie au suivant par un identifiant stable :

```
Événement redouté (ER) → Scénario stratégique (SS) → Risque (R01 à R10)
        → Mesure de l'Annexe A (5.1 à 8.34) → Action (A01 à A28) → Indicateur
```

Exemple : la divulgation massive de données (ER1) peut résulter d'un défaut de contrôle d'accès de l'API (SS2, risque R02). Ce risque justifie notamment les mesures 8.3, 8.26 et 8.28, mises en œuvre par l'action A14, dont l'indicateur est la couverture des points d'accès par des tests d'autorisation.

Le script `outils/verifier_coherence.py` contrôle cette chaîne : identifiants existants, niveaux de risque conformes à la matrice, calcul des niveaux de menace, décomptes de la déclaration d'applicabilité, cohérence entre le traitement des risques et le plan d'actions.

```
python3 outils/verifier_coherence.py   # contrôle de cohérence
bash outils/generer_pdf.sh             # export PDF (pandoc + Chrome)
```

Trois enseignements

1. **« Notre hébergeur est certifié HDS » ne suffit pas.** La certification couvre les activités que chaque acteur réalise. Un éditeur qui administre lui-même sa production réalise une activité d'hébergement.

2. **Les parties prenantes les plus dangereuses ne sont pas les sous-traitants sous contrat.** Le calcul de l'atelier 3 place en zone de danger les postes des praticiens et les dépendances logicielles.
3. **Une seule analyse de risques alimente quatre cadres.** RGPD, HDS, ISO 27001 et NIS2 se recouvrent largement : le plan d'actions issu d'EBIOS RM couvre tous les écarts majeurs relevés.

Référentiels utilisés

EBIOS Risk Manager (ANSSI) ; RGPD et guides AIPD de la CNIL ; ISO/IEC 27001:2022 ; référentiel de certification HDS v2 et PGSSI-S (ANS) ; directive (UE) 2022/2555 dite NIS2.

Limites

- Cas fictif : aucune donnée réelle, aucun entretien, aucune preuve d'audit.
- Vraisemblances estimées par la méthode expresse.
- Numéros d'exigence HDS non reproduits ; intitulés de l'Annexe A à contrôler sur la norme.
- Qualifications juridiques (activité 5 HDS, NIS2, rôles RGPD) présentées avec leur niveau de confiance en annexe.

Auteur

Taha LAHJOUJI, M2 Cybersécurité et e-santé, Université Paris Cité. Novembre 2026.

1. Cadrage du cas d'étude

> **Cas fictif.** Télémédix SAS, ses clients, son hébergeur et ses sous-traitants n'existent pas. Toute ressemblance avec une société réelle est fortuite. Les chiffres sont des hypothèses de travail.

1.1 Fiche d'identité

Élément	Valeur (hypothèse)
Éditeur	**Télémédix SAS**, Paris, créée en 2019
Produit	**Télémédix** : plateforme SaaS de téléconsultation (web + applications iOS/Android)
Modèle	B2B2C : l'éditeur vend la plateforme à des professionnels et structures de santé ; les patients sont les utilisateurs finaux
Effectif	52 salariés (ETP)
Chiffre d'affaires / total bilan	6,8 M€ / 5,1 M€
Clients	1 900 professionnels de santé libéraux, 40 centres de santé, 1 centre hospitalier
Volumétrie	150 000 patients inscrits, 2 000 comptes professionnels, 30 000 téléconsultations par mois
Fonctions	Prise de rendez-vous, salle d'attente virtuelle, visio/audio, messagerie instantanée de consultation, dépôt de documents, compte rendu, ordonnance, paiement de l'acte
Statut	Éditeur de logiciel. Télémédix **ne salarie pas de médecins** : ce n'est pas une « société de téléconsultation » au sens du code de la santé publique
Dispositif médical	Non : aucune fonction d'aide au diagnostic ou à la décision thérapeutique

Organisation interne

Équipe	Effectif	Rôle vis-à-vis de la sécurité
Direction (DG, CTO, DAF)	3	Approuve la PSSI, accepte les risques résiduels
Produit et développement	22	Développement sécurisé, revue de code
Exploitation (SRE)	5	Administration des VM, bases, sauvegardes, supervision
Support client	8	Assistance aux professionnels et aux patients
Commercial et marketing	8	Aucun accès à la production

Équipe	Effectif	Rôle vis-à-vis de la sécurité
Administration, RH, finance	4	Aucun accès à la production
RSSI	1 (50 % sécurité, 50 % SRE)	Pilote la sécurité ; rattaché au CTO (écart : voir §1.7)
Qualité et conformité	1	Relais du DPO, gestion documentaire
DPO	Externe (cabinet)	Conseil et contrôle RGPD

1.2 Périmètre de l'étude

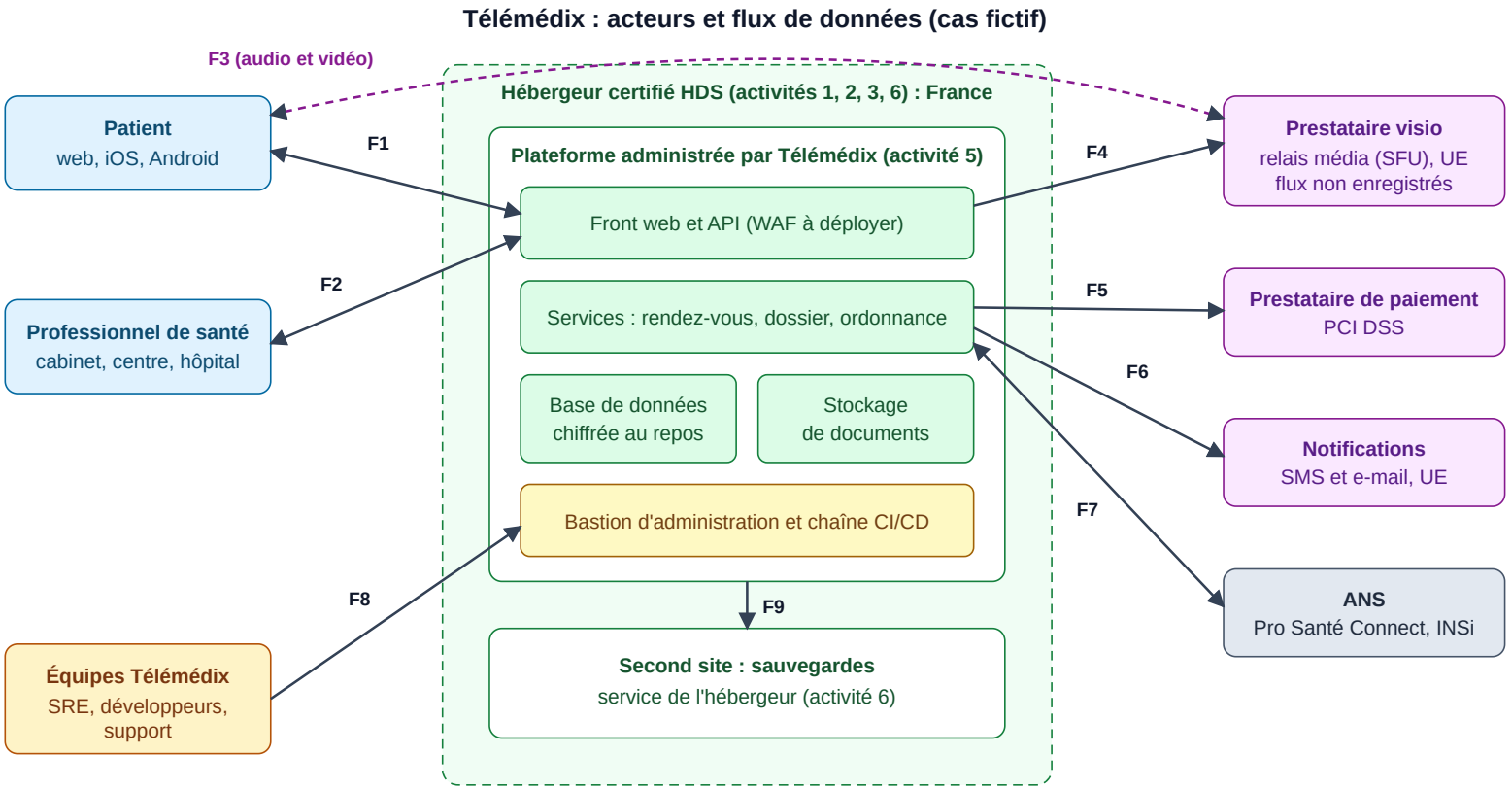
Dans le périmètre	Hors périmètre (justification)
Plateforme Télémédix en production (front, API, bases, stockage, sauvegardes)	Bureautique générale, paie, CRM commercial (pas de données de santé ; couverts par le socle d'hygiène)
Processus de développement et de déploiement (dépôt de code, CI/CD)	Systèmes d'information des clients (logiciel de cabinet, SIH) : responsabilité des clients
Processus d'exploitation et d'administration	Terminaux des patients : non maîtrisables, traités comme partie prenante
Processus de support client (accès aux comptes)	Alimentation du DMP / Mon espace santé : évolution prévue, non déployée
Relations avec l'hébergeur et les trois sous-traitants	Sécurité physique des centres de données : portée par l'hébergeur certifié

1.3 Acteurs et rôles

Acteur	Rôle opérationnel	Qualification RGPD	Qualification HDS
Professionnels et structures de santé (clients)	Réalisent les téléconsultations, tiennent le dossier	**Responsables de traitement** de la prise en charge	Clients de l'hébergement (ils confient des données de santé à un tiers)
Télémédix SAS	Édite, administre et exploite la plateforme	**Sous-traitant** des clients pour la téléconsultation et le dossier ; **responsable de traitement** pour le compte utilisateur patient, la relation client, le support et la sécurité	Réalise l'**activité 5** (administration et exploitation). Non certifiée à ce jour : **écart majeur**, voir dossier 5
Hébergeur « HexaSanté Cloud » (fictif)	Fournit centres de données, serveurs, virtualisation, service de sauvegarde ; deux sites en France	Sous-traitant ultérieur	Certifié HDS, activités 1, 2, 3 et 6
Prestataire visio « VisioLink EU » (fictif)	Serveurs de relais média (SFU) mutualisés, hébergés dans l'UE	Sous-traitant ultérieur. Il traite des données de santé : sans chiffrement de bout en bout, le flux est déchiffré sur ses serveurs	Flux en transit, non conservés : qualification à vérifier (voir annexe)
Prestataire de paiement « PayNord » (fictif)	Encaissement par carte, certifié PCI DSS niveau 1	Sous-traitant ultérieur (ou responsable distinct pour ses obligations propres de lutte contre la fraude)	Sans objet : aucune donnée de santé

Acteur	Rôle opérationnel	Qualification RGPD	Qualification HDS
Prestataire de notifications « NotifExpress » (fictif)	Envoi de SMS et d'e-mails transactionnels, UE	Sous-traitant ultérieur	Sans objet **si** les messages ne contiennent aucune donnée de santé
ANS	Pro Santé Connect, téléservice INSi	Tiers (services socles nationaux)	Sans objet
Patients	Utilisateurs finaux	Personnes concernées	Sans objet
DPO externe	Conseil, contrôle	Sans objet	Sans objet

1.4 Architecture et flux de données



Trait pointillé violet : flux média direct entre les terminaux et le prestataire visio. Le détail des flux F1 à F9 figure au §1.4.

Flux	De → vers	Contenu	Donnée de santé ?	Protection actuelle
F1	Patient ↔ plateforme	Identité, rendez-vous, documents déposés, messages	Oui	TLS 1.2+ ; mot de passe seul
F2	Professionnel ↔ plateforme	Comptes rendus, ordonnances, agenda	Oui	TLS 1.2+ ; mot de passe, OTP SMS facultatif
F3	Patient/professionnel ↔ prestataire visio	Flux audio et vidéo temps réel, non enregistrés	Oui	DTLS-SRTP de saut en saut ; pas de chiffrement de bout en bout
F4	Plateforme → prestataire visio	Création de salle, jetons d'accès, identifiants techniques	Non (pseudonymes)	API authentifiée, TLS
F5	Plateforme → prestataire de paiement	Montant, identifiant de transaction ; la carte est saisie sur la page du prestataire	Non	Redirection hébergée (périmètre PCI DSS réduit)
F6	Plateforme → prestataire de notifications	Numéro ou e-mail, texte du message	Aujourd'hui **oui** (nom et spécialité du praticien dans le message)	TLS ; écart de minimisation
F7	Plateforme ↔ ANS	Authentification du professionnel, vérification d'identité INS	Identifiant national de santé	Cible : Pro Santé Connect et INSi ; non déployé
F8	Équipes Télémédix → plateforme	Administration, support, déploiements	Accès possible	VPN, bastion SSH, MFA partiel
F9	Plateforme → sauvegardes (second site de l'hébergeur)	Copies complètes des bases et documents	Oui	Chiffrement au repos ; même compte d'administration que la production

1.5 Données traitées et classification

Échelle de classification : **C1** public, **C2** interne, **C3** confidentiel, **C4** secret (données de santé, secrets techniques). Besoins de sécurité notés de 1 (faible) à 4 (vital) : Disponibilité, Intégrité, Confidentialité, Traçabilité.

Réf.	Donnée	Personnes	Classe	D	I	C	T	Remarque
D1	Identité et coordonnées du patient	Patients	C3	2	3	3	3	
D2	Identifiant national de santé (matricule INS, fondé sur le NIR)	Patients	C4	2	4	4	4	Usage encadré par le référentiel INS
D3	Données médicales : motif, compte rendu, ordonnance, documents, messages	Patients	C4	3	4	4	4	Cœur du secret médical
D4	Flux audio et vidéo	Patients, professionnels	C4	4	2	4	2	Non enregistré (minimisation)
D5	Données de rendez-vous : date, praticien, spécialité	Patients	C4	3	3	4	3	La spécialité révèle indirectement l'état de santé
D6	Identité professionnelle (RPPS, spécialité)	Professionnels	C2	2	4	2	3	Intégrité critique : usurpation
D7	Données de paiement : jeton, montant, statut	Patients	C3	2	3	3	3	Numéro de carte jamais stocké

Réf.	Donnée	Personnes	Classe	D	I	C	T	Remarque
D8	Journaux et traces d'accès	Tous utilisateurs, salariés	C3	2	4	3	4	Valeur probante
D9	Secrets techniques : clés, mots de passe, jetons CI/CD	Sans objet	C4	3	4	4	4	
D10	Code source et configuration	Sans objet	C3	2	4	3	3	

1.6 Cadre réglementaire et normatif retenu

Texte ou référentiel	S'applique à Télémédix ?	Traité dans
RGPD et loi Informatique et Libertés	Oui, comme sous-traitant et comme responsable de traitement	Dossier 3
Code de la santé publique, art. L.1111-8 (hébergement de données de santé)	Oui : l'hébergeur doit être certifié ; l'éditeur aussi s'il réalise une activité d'hébergement	Dossier 5
Référentiel de certification HDS v2 (ANS)	Oui pour l'activité 5 (analyse en dossier 5)	Dossier 5
ISO/IEC 27001:2022	Volontaire, mais prérequis de la certification HDS	Dossier 4
PGSSI-S et référentiels ANS (INS, Pro Santé Connect)	Oui, opposables aux services numériques en santé	Dossiers 2 et 4 (socle)
Référentiel d'interopérabilité, de sécurité et d'éthique des SI de téléconsultation (ANS)	Oui pour l'éditeur d'un SI de téléconsultation ; calendrier d'opposabilité aux éditeurs à vérifier	Mentionné, hors périmètre détaillé
Directive NIS2 (UE) 2022/2555	**Non transposée en France au 11/11/2026** ; applicabilité analysée	Dossier 5
PCI DSS	Indirectement : encaissement délégué à un prestataire certifié	Dossier 2 (partie prenante)
Règlement (UE) 2017/745 (dispositifs médicaux)	Non : pas de finalité médicale propre au logiciel	Sans objet

1.7 État initial de la sécurité (point de départ fictif)

Ce socle sert de base aux ateliers EBIOS RM. Il décrit une scale-up réaliste : des bonnes pratiques techniques, peu de formalisation.

Domaine	Existant	Écart principal
Gouvernance	Charte informatique ; RSSI à mi-temps rattaché au CTO ; DPO externe	Pas de PSSI, pas de SMSI, pas de comité sécurité ; RSSI juge et partie
Conformité RGPD	Registre partiel ; contrats de sous-traitance signés avec les trois prestataires	Pas d'AIPD ; durées de conservation non appliquées techniquement
Authentification	MFA TOTP sur le bastion ; mot de passe + OTP SMS facultatif pour les professionnels ; mot de passe seul pour les patients	MFA absent sur la console de l'hébergeur et sur la CI/CD ; Pro Santé Connect non déployé
Chiffrement	TLS 1.2+ ; chiffrement des disques et des bases au repos	Pas de chiffrement applicatif des documents ; visio sans chiffrement de bout en bout

Domaine	Existant	Écart principal
Sauvegardes	Quotidiennes, sur le second site de l'hébergeur	Même compte que la production, non immuables ; restauration jamais testée formellement
Journalisation	Journaux applicatifs conservés 3 mois	Accès aux dossiers tracés partiellement ; ni centralisation ni alerte
Développement	Revue de code par un pair ; test d'intrusion annuel (le dernier date de 14 mois)	Pas d'analyse automatique du code ni des dépendances ; données de production copiées en recette
Exploitation	Correctifs mensuels ; antivirus et chiffrement sur les postes, gérés par MDM	Pas d'EDR ; pas de délai de correction formalisé ; réseau de production peu cloisonné
Support	Fonction « se connecter en tant que » pour dépanner un utilisateur	Pas de justification, pas de limite de durée, pas de revue
Continuité	Second site passif chez l'hébergeur	PRA jamais testé ; RTO et RPO non définis
Sensibilisation	Session à l'arrivée	Aucun suivi ni exercice

1.8 Hypothèses structurantes et justification des choix

#	Choix	Pourquoi (argument d'entretien)
H1	L'éditeur administre lui-même ses VM	Cas le plus fréquent chez les éditeurs SaaS santé et le plus instructif : il fait apparaître la question de l'activité 5 HDS, que l'on oublie quand on se contente de dire « notre hébergeur est certifié »
H2	52 salariés, 6,8 M€ de chiffre d'affaires	Juste au-dessus du seuil de 50 personnes : la qualification NIS2 dépend alors du secteur et non plus de la taille, ce qui oblige à argumenter
H3	Visio sous-traitée, sans chiffrement de bout en bout	Réaliste (architecture SFU) et discriminant : « chiffré » ne veut pas dire « illisible par le prestataire »
H4	Pas d'enregistrement des consultations	Minimisation ; réduit fortement la gravité d'une compromission du prestataire visio
H5	Télémédix responsable de traitement du compte patient	Le compte est unique et sert auprès de plusieurs praticiens : l'éditeur en fixe finalités et moyens. Qualification à valider avec le DPO (voir annexe)
H6	Encaissement par redirection vers le prestataire	Aucune donnée de carte ne transite par la plateforme : le périmètre PCI DSS est réduit au minimum
H7	Aucun transfert hors UE pour les données de santé	Cohérent avec les exigences de localisation du référentiel HDS v2 ; les notifications push (Apple, Google) ne portent aucun contenu
H8	Télémédix n'emploie pas de médecins	Évite le régime d'agrément des sociétés de téléconsultation, qui est un sujet distinct de la conformité cyber
H9	État initial imparfait	Un dossier sans écart ne démontre rien : la valeur est dans le lien risque → mesure → action

2. Analyse de risques EBIOS Risk Manager

Méthode : EBIOS Risk Manager (ANSSI), ateliers 1 à 5. Objet de l'étude : la plateforme Télémédix et ses processus de développement, d'exploitation et de support (périmètre du dossier 1).

Paramètre de l'étude	Choix
Objectif	Identifier les risques numériques, justifier la déclaration d'applicabilité ISO 27001 et bâtir le plan d'actions
Participants (fictifs)	DG, CTO, RSSI, responsable SRE, responsable développement, responsable support, DPO, un médecin utilisateur (représentant métier)
Cycle stratégique	Révision complète tous les 2 ans ou après un changement majeur
Cycle opérationnel	Revue des scénarios opérationnels et du plan d'actions chaque année
Cotation de la vraisemblance	Méthode expresse du guide (estimation globale argumentée)

Échelles

Gravité (impact sur les patients, les clients et l'entreprise)

Niveau	Libellé	Critères
G1	Mineure	Gêne passagère, aucune conséquence sur la prise en charge ni sur la vie privée
G2	Significative	Dégradation du service ou atteinte réversible touchant moins de 100 personnes ; préjudice financier limité
G3	Grave	Divulgation de données de santé ou atteinte à l'intégrité touchant de 100 à 10 000 personnes ; perte de chance ponctuelle pour des patients ; sanction probable, départ de clients
G4	Critique	Divulgation massive et irréversible (plus de 10 000 patients), mise en danger de patients ou perte définitive de dossiers ; survie de l'entreprise menacée

Vraisemblance

Niveau	Libellé	Critères
V1	Peu vraisemblable	L'attaquant devrait franchir plusieurs barrières robustes et indépendantes
V2	Vraisemblable	Réalisable avec des moyens importants ou un concours de circonstances
V3	Très vraisemblable	Réalisable avec des techniques courantes ; mode opératoire observé dans le secteur
V4	Quasi certain	Attaque automatisable, déjà observée ou attendue à court terme

Niveau de risque

	V1	V2	V3	V4
G4	Moyen	Élevé	Élevé	Élevé
G3	Moyen	Moyen	Élevé	Élevé
G2	Faible	Faible	Moyen	Moyen
G1	Faible	Faible	Faible	Faible

Élevé : inacceptable, à traiter en priorité. Moyen : tolérable sous surveillance, acceptation formelle par la direction. Faible : acceptable.

Atelier 1 : cadrage et socle de sécurité

Valeurs métier

Réf.	Valeur métier	Nature	Responsable
VM1	Réaliser une téléconsultation (visio, audio, messagerie en temps réel)	Processus	Directeur produit
VM2	Tenir le dossier de téléconsultation (comptes rendus, ordonnances, documents)	Information	Directeur produit ; les clients en sont responsables de traitement
VM3	Gérer les identités, les comptes et les rendez-vous	Processus et information	Directeur produit
VM4	Encaisser les actes	Processus	DAF

Biens supports

Réf.	Bien support	Valeurs métier portées	Responsable
BS1	Applications web et mobiles	VM1 à VM4	Responsable développement
BS2	API et services applicatifs	VM1 à VM4	Responsable développement
BS3	Bases de données et stockage de documents	VM2, VM3	Responsable SRE
BS4	Infrastructure virtuelle, réseau et sauvegardes (hébergeur)	VM1 à VM4	Responsable SRE ; hébergeur
BS5	Dépôt de code et chaîne CI/CD	VM1 à VM4	Responsable développement
BS6	Postes d'administration et bastion	VM1 à VM4	Responsable SRE
BS7	Service de visio (tiers)	VM1	Prestataire visio
BS8	Service de paiement (tiers)	VM4	Prestataire de paiement
BS9	Service de notifications (tiers)	VM3	Prestataire de notifications
BS10	Outils de support (tickets, connexion « en tant que »)	VM2, VM3	Responsable support

Réf.	Bien support	Valeurs métier portées	Responsable
BS11	Personnel à privilèges (SRE, développeurs, support)	VM1 à VM4	CTO

Événements redoutés

Réf.	Valeur métier	Événement redouté	Critère	Impacts	Gravité
ER1	VM2	Divulgation massive de données de santé	C	Atteinte irréversible à la vie privée, chantage aux patients, sanction CNIL, perte de confiance	G4
ER2	VM2	Altération de comptes rendus ou d'ordonnances	I	Erreur de prise en charge, détournement de médicaments	G3
ER3	VM1	Indisponibilité de la téléconsultation pendant plus de 4 heures ouvrées	D	Consultations annulées, perte de chance ponctuelle, pénalités contractuelles	G3
ER4	VM1	Écoute ou interception de téléconsultations	C	Violation du secret médical	G3
ER5	VM3	Usurpation de l'identité d'un professionnel de santé	I	Fausses ordonnances, faux arrêts de travail, responsabilité du praticien engagée	G3
ER6	VM3	Prise de contrôle de comptes patients	C	Accès au dossier, usurpation, hameçonnage ciblé	G3
ER7	VM2	Perte irréversible de dossiers	D, I	Rupture de la continuité des soins, manquement des clients à leur obligation de conservation	G4
ER8	VM4	Fraude ou détournement de paiements	I	Préjudice financier, litiges	G2
ER9	VM2, VM3	Consultation illégitime de dossiers par un membre du personnel	C	Violation du secret, plainte, sanction	G3

Socle de sécurité

Référentiel	Statut	Écarts principaux (détail au dossier 1, §1.7)
RGPD	Partiellement appliqué	AIPD absente, durées de conservation non automatisées
Certification HDS	Hébergeur certifié (activités 1, 2, 3, 6) ; éditeur non certifié	Activité 5 réalisée par l'éditeur sans certification
PGSSI-S et services socles (Pro Santé Connect, INS)	Partiellement appliqué	Authentification des professionnels non conforme à la cible
Guide d'hygiène informatique de l'ANSSI	Partiellement appliqué	MFA partiel, cloisonnement, journalisation, sauvegardes non testées
ISO/IEC 27001:2022	Non appliqué	Pas de SMSI
PCI DSS	Délégué au prestataire	Attestation de conformité du prestataire à collecter chaque année

Les écarts au socle sont traités directement dans le plan d'actions ; ils alimentent aussi la vraisemblance des scénarios de l'atelier 4.

Atelier 2 : sources de risque et objectifs visés

Cotation de 1 (faible) à 4 (forte). La pertinence combine motivation, ressources et activité observée dans le secteur de la santé.

Réf.	Source de risque	Objectif visé	Motivation	Ressources	Activité	Pertinence	Retenu
SR1	Groupe cybercriminel organisé	Extorquer l'éditeur par rançongiciel et menace de publication	4	3	4	Élevée	Oui
SR2	Cybercriminel (vol de données)	Voler en masse des données de santé et d'identité pour les revendre	4	3	3	Élevée	Oui
SR3	Fraudeur	Obtenir de fausses ordonnances ou de faux arrêts de travail, détourner des paiements	3	2	3	Élevée	Oui
SR4	Salarié ou prestataire indélicat	Consulter ou exfiltrer des dossiers (curiosité, vengeance, revente)	2	3	2	Moyenne	Oui
SR5	Hacktiviste	Rendre le service indisponible pour nuire à l'image	2	2	2	Moyenne	Oui
SR6	Acteur étatique	Espionner des patients ciblés	2	4	1	Faible	Non
SR7	Concurrent	Voler le code source ou la base clients	1	2	1	Faible	Non
SR8	Attaquant opportuniste isolé	Défi, dégradation	2	1	3	Faible	Non

Justification des écarts. SR6 : la plateforme ne vise pas de population stratégique et l'attaquant dispose de voies plus directes ; à réévaluer si un client sensible est signé. SR7 : aucun cas documenté dans ce secteur, impact limité. SR8 : couvert par le socle (correctifs, durcissement) et par les scénarios de SR2, plus exigeants.

Atelier 3 : scénarios stratégiques

Cartographie de l'écosystème

Niveau de menace = (dépendance × pénétration) / (maturité cyber × confiance), chaque critère étant coté de 1 à 4. Seuils retenus : **zone de danger** à partir de 2,5 ; **zone de contrôle** de 1,0 à moins de 2,5 ; **zone de veille** en dessous de 1,0.

Réf.	Partie prenante	Dépendance	Pénétration	Maturité	Confiance	Niveau de menace	Zone
PP1	Hébergeur HDS	4	4	4	4	1,00	Contrôle
PP2	Prestataire visio	4	3	3	3	1,33	Contrôle

Réf.	Partie prenante	Dépendance	Pénétration	Maturité	Confiance	Niveau de menace	Zone
PP3	Prestataire de paiement	2	1	4	4	0,13	Veille
PP4	Prestataire de notifications	2	2	2	3	0,67	Veille
PP5	Clients : professionnels de santé et leurs postes	3	3	1	3	3,00	Danger
PP6	Patients et leurs terminaux	1	1	1	2	0,50	Veille
PP7	Fournisseur du dépôt de code et de la CI/CD (SaaS)	3	4	3	3	1,33	Contrôle
PP8	Éditeur de l'outil de tickets (SaaS)	2	2	3	3	0,44	Veille
PP9	ANS (Pro Santé Connect, INSi)	3	2	4	4	0,38	Veille
PP10	Dépendances logicielles open source	4	4	2	2	4,00	Danger

Lecture. Les deux parties prenantes les plus dangereuses ne sont pas les sous-traitants contractuels : ce sont les postes des professionnels (non maîtrisés, accès légitime aux dossiers) et les dépendances logicielles (exécutées en production sans relation contractuelle).

Scénarios stratégiques

Réf.	Source / objectif	Chemin d'attaque	Parties prenantes	Événements redoutés	Gravité
SS1	SR1 : extorsion	Compromission d'un administrateur, prise de contrôle de l'infrastructure, exfiltration puis chiffrement de la production et des sauvegardes	PP1	ER1, ER3, ER7	G4
SS2	SR2 : vol de masse	Exploitation d'un défaut de contrôle d'accès de l'API depuis un compte légitime, extraction automatisée	Aucune	ER1	G4
SS3	SR2 : vol de masse	Compromission de la chaîne logicielle (jeton CI/CD ou dépendance piégée), déploiement de code malveillant	PP7, PP10	ER1, ER2	G4
SS4	SR3 : fraude	Vol des identifiants d'un professionnel, émission de fausses ordonnances ou d'arrêts de travail	PP5	ER5, ER2	G3
SS5	SR2 ou SR3 : comptes patients	Réutilisation massive d'identifiants volés ailleurs, accès aux dossiers	PP6	ER6	G3
SS6	SR4 : interne	Usage détourné de la connexion « en tant que » ou d'un accès direct aux bases	Aucune	ER9, ER1	G3
SS7	SR5 ou SR1 : indisponibilité	Déni de service sur le front, ou défaillance du prestataire visio ou de l'hébergeur	PP1, PP2	ER3	G3
SS8	SR2 : écoute	Compromission des relais média du prestataire visio	PP2	ER4	G3
SS9	SR2 : canaux secondaires	Compromission du prestataire de notifications ou de l'outil de tickets, récupération des contenus	PP4, PP8	ER1 (partiel)	G2
SS10	SR3 : fraude financière	Détournement de paiements ou de remboursements	PP3	ER8	G2

Mesures de sécurité sur l'écosystème

Partie prenante	Mesures (actions du dossier 6)	Effet attendu
PP5 Clients	A06, A27	Baisse de la pénétration : l'authentification ne repose plus sur le seul poste du praticien
PP10 Dépendances	A15	Hausse de la maturité : inventaire, versions figées, analyse automatique
PP7 Dépôt et CI/CD	A05, A15	Baisse de la pénétration : jetons à durée courte, MFA, artefacts signés
PP2 Visio	A24	Baisse de la pénétration : chiffrement de bout en bout ; plan de sortie
PP1 Hébergeur	A11, A25	Baisse de la dépendance : sauvegardes isolées ; suivi du certificat
PP4, PP8 Notifications et tickets	A12, A25	Baisse de la pénétration : plus aucune donnée de santé dans ces canaux

---

Atelier 4 : scénarios opérationnels

Chaque scénario stratégique donne un risque. Les quatre risques les plus graves sont détaillés selon la séquence Connaître, Rentrer, Trouver, Exploiter.

R01 : rançongiciel avec double extorsion (SS1)

Phase	Actions élémentaires	Biens supports
Connaître	Repérage des administrateurs sur les réseaux professionnels ; les offres d'emploi révèlent la pile technique	BS11
Rentrer	Hameçonnage ciblé d'un SRE et vol de session par un logiciel voleur d'informations ; variante : exploitation d'un accès VPN non corrigé	BS6, BS11
Trouver	Rebond par le bastion, récupération de secrets, accès à la console de l'hébergeur, repérage des sauvegardes	BS4, BS6
Exploiter	Exfiltration des bases et des documents, suppression des sauvegardes, chiffrement des VM, demande de rançon	BS3, BS4

Vraisemblance **V3** : MFA absent sur la console, pas d'EDR, sauvegardes accessibles depuis le même compte, aucune détection ; le secteur de la santé est une cible habituelle de ces groupes.

R02 : extraction massive par défaut de contrôle d'accès (SS2)

Phase	Actions élémentaires	Biens supports
Connaître	Création d'un compte patient, analyse de l'application mobile et des appels à l'API	BS1, BS2
Rentrer	Aucune intrusion : l'attaquant agit avec son propre compte authentifié	BS2
Trouver	Découverte d'un point d'accès qui renvoie un document sans vérifier qu'il appartient à l'appelant (référence directe non contrôlée)	BS2
Exploiter	Énumération lente et automatisée des identifiants, extraction des documents, revente	BS3

Vraisemblance **V3** : aucun test d'autorisation automatisé, dernier test d'intrusion vieux de 14 mois, aucune alerte sur les volumes consultés. Ce défaut est le plus fréquent sur les API.

R03 : compromission de la chaîne logicielle (SS3)

Phase	Actions élémentaires	Biens supports
Connaître	Identification des dépendances et des développeurs	BS5
Rentrer	Vol d'un jeton d'accès au dépôt sur le poste d'un développeur ; variante : publication d'une version piégée d'une dépendance	BS5, BS11
Trouver	Lecture des secrets de déploiement stockés dans la CI/CD	BS5
Exploiter	Ajout de code qui exfiltre les données ou ouvre une porte dérobée ; déploiement automatique en production	BS2, BS3

Vraisemblance **V2** : la revue par un pair existe, mais les secrets de déploiement sont à longue durée de vie et les dépendances ne sont ni figées ni analysées.

R04 : usurpation d'un compte de professionnel de santé (SS4)

Phase	Actions élémentaires	Biens supports
Connaître	Liste des praticiens dans l'annuaire public de la plateforme	BS1
Rentrer	Hameçonnage imitant la page de connexion ; variante : logiciel malveillant sur le poste du cabinet	BS1
Trouver	Accès à l'agenda et aux dossiers du praticien	BS2
Exploiter	Émission d'ordonnances ou d'arrêts de travail au nom du praticien ; consultation des dossiers de ses patients	BS2, BS3

Vraisemblance **V3** : second facteur facultatif, postes des cabinets hors de tout contrôle, fraude aux arrêts de travail en ligne déjà observée.

Autres scénarios opérationnels

Risque	Scénario (résumé)	Biens supports	Vraisemblance	Justification
R05	Test automatisé de couples identifiant/mot de passe issus de fuites tierces sur l'espace patient, puis accès aux dossiers (SS5)	BS1, BS2	V4	Mot de passe seul, pas de limitation de débit avancée ; attaque entièrement automatisée
R06	Un agent du support ou un administrateur consulte ou exporte des dossiers sans besoin (SS6)	BS10, BS3, BS11	V2	Fonction « en tant que » sans justification ni revue ; effectif restreint et contractuellement tenu au secret
R07	Saturation du front par déni de service, ou panne prolongée du prestataire visio ou de l'hébergeur (SS7)	BS1, BS4, BS7	V3	Pas de protection anti-DDoS dédiée, prestataire visio unique, PRA jamais testé
R08	Compromission des relais média du prestataire : écoute de consultations en cours (SS8)	BS7	V2	Flux déchiffré sur le relais ; attaque ciblée et complexe ; rien n'est enregistré

Risque	Scénario (résumé)	Biens supports	Vraisemblance	Justification
R09	Compromission du prestataire de notifications ou de l'outil de tickets : accès aux messages et pièces jointes (SS9)	BS9, BS10	V3	Messages contenant praticien et spécialité ; pièces jointes de tickets jamais purgées
R10	Détournement de paiements ou de remboursements par fraude ou compromission d'un compte (SS10)	BS8	V2	Encaissement délégué à un prestataire certifié ; contrôles antifraude du prestataire

---

Atelier 5 : traitement du risque

Synthèse des risques

Risque	Intitulé	Gravité	Vraisemblance	Niveau initial
R01	Rançongiciel avec double extorsion	G4	V3	Élevé
R02	Extraction massive par défaut de contrôle d'accès	G4	V3	Élevé
R03	Compromission de la chaîne logicielle	G4	V2	Élevé
R04	Usurpation d'un compte de professionnel	G3	V3	Élevé
R05	Prise de contrôle de comptes patients	G3	V4	Élevé
R06	Consultation illégitime par le personnel	G3	V2	Moyen
R07	Indisponibilité prolongée	G3	V3	Élevé
R08	Écoute de téléconsultations chez le prestataire visio	G3	V2	Moyen
R09	Fuite par les canaux secondaires	G2	V3	Moyen
R10	Fraude au paiement	G2	V2	Faible

Dix risques, dont six élevés : un volume cohérent avec cinq couples source/objectif et dix scénarios stratégiques, et pilotable par une équipe de cette taille.

Cartographie initiale

	V1	V2	V3	V4
G4		R03	R01, R02	
G3		R06, R08	R04, R07	R05
G2		R10	R09	
G1				

Stratégie de traitement et risques résiduels

Risque	Option	Mesures (actions du dossier 6)	Gravité résiduelle	Vraisemblance résiduelle	Niveau résiduel
R01	Réduire	A05, A10, A11, A18, A19, A20, A21, A22, A26	G4	V1	Moyen
R02	Réduire	A10, A14, A16, A17, A18, A20, A21	G4	V1	Moyen
R03	Réduire	A05, A15, A19, A25	G4	V1	Moyen
R04	Réduire	A06, A16, A27	G3	V2	Moyen
R05	Réduire	A07, A16, A18	G3	V2	Moyen
R06	Réduire	A08, A09, A10, A17, A18, A26	G3	V1	Moyen
R07	Réduire	A11, A21, A22, A23, A24, A25	G3	V2	Moyen
R08	Réduire	A24, A25	G3	V1	Moyen
R09	Réduire	A04, A12, A13, A25	G2	V2	Faible
R10	Transférer et réduire	A12, A25	G2	V1	Faible

Cartographie résiduelle (après réalisation du plan)

	V1	V2	V3	V4
G4	R01, R02, R03			
G3	R06, R08	R04, R05, R07		
G2	R10	R09		
G1				

Acceptation. Plus aucun risque élevé. Les huit risques résiduels moyens sont soumis à l'acceptation formelle de la direction générale, avec revue annuelle. La gravité des risques R01 à R03 reste G4 : les mesures agissent sur la vraisemblance, pas sur le volume de données exposées. Seul le chiffrement applicatif (A10) limite aussi l'impact, sans le faire changer de niveau.

Justification des choix (arguments d'entretien)

Choix	Justification
Dix risques	Le guide recommande de retenir quelques couples source/objectif pertinents plutôt que de viser l'exhaustivité ; au-delà d'une quinzaine de risques, une structure de 52 personnes ne peut plus les piloter
Risques accidentels absents	EBIOS RM traite les menaces intentionnelles par scénarios ; pannes et erreurs relèvent du socle de sécurité (atelier 1) et de la continuité (A11, A23)

Choix	Justification
Acteur étatique écarté	Écart assumé et tracé ; une étude doit montrer ce qu'elle exclut et pourquoi
Méthode expresse	Adaptée à une première itération ; la méthode standard (probabilité et difficulté par action élémentaire) est prévue au prochain cycle opérationnel pour R01 et R02
Gravité inchangée après traitement	Position prudente : promettre qu'une fuite deviendra moins grave grâce à des mesures préventives fausse la décision de la direction
Clients et dépendances en zone de danger	Résultat du calcul, pas d'une intuition : faible maturité et forte pénétration pèsent plus que le caractère « externe » d'un sous-traitant certifié

3. Analyse d'impact relative à la protection des données et registre

Méthode : trame de la CNIL (contexte, principes fondamentaux, risques, validation). Les risques pour les personnes s'appuient sur l'étude EBIOS RM (dossier 2).

3.1 Qui doit réaliser l'AIPD ?

Traitement	Responsable de traitement	Rôle de Télémédix	Conséquence
Téléconsultation et tenue du dossier	Chaque client (professionnel ou structure de santé)	Sous-traitant	L'obligation d'AIPD pèse sur le client. Télémédix doit l'**aider** (RGPD, art. 28.3.f) : elle fournit la présente analyse comme **AIPD type**, que chaque client adapte et valide
Compte utilisateur patient	Télémédix	Responsable de traitement	Télémédix réalise et valide elle-même l'AIPD

Pourquoi une AIPD est obligatoire. Le traitement cumule plusieurs critères de risque élevé retenus par les lignes directrices européennes : données sensibles (santé), grande échelle (150 000 patients), personnes vulnérables (patients). Il correspond aussi aux types de traitements de données de santé que la CNIL soumet à AIPD. Deux critères suffisent.

3.2 Description du traitement

Rubrique	Contenu
Finalité principale	Permettre la réalisation d'actes de téléconsultation et la tenue du dossier associé
Finalités secondaires	Prise de rendez-vous et rappels ; encaissement de l'acte ; authentification et sécurité ; assistance aux utilisateurs
Finalités exclues	Prospection auprès des patients, revente ou réutilisation des données de santé, profilage, entraînement de modèles sur les données de santé
Personnes concernées	Patients (dont mineurs représentés par un titulaire de l'autorité parentale), professionnels de santé
Données	Voir inventaire D1 à D8 du dossier 1, §1.5
Destinataires	Le professionnel consulté et, le cas échéant, l'équipe de soins au sens du code de la santé publique ; le patient ; le personnel habilité de Télémédix dans la stricte limite du support et de l'exploitation
Sous-traitants ultérieurs	Hébergeur HDS (France), prestataire visio (UE), prestataire de paiement (UE), prestataire de notifications (UE)
Transferts hors UE	Aucun pour les données de santé. Notifications push via les services d'Apple et de Google : message sans contenu (« Vous avez une notification »)
Supports	Voir biens supports BS1 à BS10 du dossier 2

3.3 Principes fondamentaux

Base légale

Finalité	Responsable	Base légale (art. 6)	Exception pour les données de santé (art. 9)	Commentaire
Téléconsultation et dossier	Client	Professionnel libéral ou centre privé : exécution du contrat de soins (6.1.b) et obligation légale de tenir le dossier (6.1.c). Hôpital public : mission d'intérêt public (6.1.e)	9.2.h : prise en charge sanitaire, par un professionnel soumis au secret (9.3)	Le **consentement n'est pas la base légale**. Le consentement du patient à l'acte de télémédecine, prévu par le code de la santé publique, est un consentement aux soins, distinct du consentement RGPD
Compte patient	Télémédix	Exécution des conditions d'utilisation (6.1.b)	9.2.h pour les données liées aux rendez-vous, traitées sous l'autorité des professionnels	Point de qualification à valider (annexe)
Rappels de rendez-vous	Client	Exécution du contrat (6.1.b)	Sans objet si le message ne contient aucune donnée de santé	Dépend de l'action A12
Encaissement	Client	Exécution du contrat (6.1.b)	Sans objet	Libellé bancaire neutre
Journalisation et sécurité	Télémédix et client	Obligation légale de sécurité (6.1.c ; RGPD art. 32 ; référentiels opposables)	Sans objet	
Statistiques d'usage	Télémédix	Intérêt légitime (6.1.f)	Sans objet : données agrégées, sans donnée de santé	Mise en balance documentée

Minimisation

Donnée	Décision	Justification
Flux audio et vidéo	Jamais enregistrés	Aucune finalité ne l'exige ; supprime un stock de données très sensibles
Motif de consultation	Champ libre facultatif, visible du seul praticien	Utile à la préparation, non indispensable
Identifiant national de santé	Collecté par le téléservice INSi, uniquement pour référencer les documents de santé	Usage limité par le référentiel INS ; jamais utilisé comme identifiant de connexion
Notifications SMS et e-mail	Message générique, sans nom de praticien ni spécialité	La spécialité révèle l'état de santé (psychiatre, oncologue)
Tickets de support	Pièces jointes interdites pour les documents médicaux ; purge à 90 jours	Le support n'a pas à connaître le contenu médical
Environnements de test	Données synthétiques uniquement	Les développeurs n'ont pas besoin de données réelles

Donnée	Décision	Justification
Libellé de paiement	Nom de l'éditeur, sans spécialité	Le relevé bancaire ne doit rien révéler
Géolocalisation, contacts, traceurs publicitaires	Non collectés	Aucune finalité

Durées de conservation

Donnée	Durée	Fondement	Qui décide
Dossier de téléconsultation (compte rendu, ordonnance, documents)	20 ans après la dernière prise en charge ; jusqu'au 28e anniversaire pour un mineur ; 10 ans après le décès	Code de la santé publique, art. R.1112-7 (établissements) ; même durée recommandée en exercice libéral	Le client. Télémédix applique ses instructions et restitue puis supprime les données en fin de contrat
Messages échangés pendant la consultation	Versés au dossier si le praticien le décide ; sinon supprimés 30 jours après l'acte	Minimisation	Le client
Flux audio et vidéo	Aucune conservation	Minimisation	Sans objet
Compte patient inactif	Suppression après 3 ans sans connexion, après avertissement ; les dossiers restent chez les praticiens	Proportionnalité	Télémédix
Traces d'accès aux dossiers	12 mois en ligne ; durée plus longue à arbitrer	Recommandation de la CNIL sur la journalisation (6 mois à 1 an) ; exigences de traçabilité du secteur	Télémédix et client
Journaux techniques	6 mois	Recommandation de la CNIL	Télémédix
Données de transaction	13 mois pour la contestation ; pièces comptables 10 ans	Recommandations de la CNIL ; code de commerce	Télémédix et client
Tickets de support	3 ans après clôture ; pièces jointes 90 jours	Preuve contractuelle ; minimisation	Télémédix
Sauvegardes	35 jours glissants	Une suppression est effective dans les sauvegardes au plus tard à l'expiration du cycle	Télémédix

Information et droits des personnes

Droit	Mise en œuvre	Limite
Information	Notice à la création du compte et avant chaque téléconsultation ; mention des rôles (praticien responsable, Télémédix sous-traitant)	
Accès	Téléchargement des documents depuis l'espace patient ; demande d'accès au dossier adressée au praticien	L'accès au dossier médical suit aussi le code de la santé publique
Rectification	Données de compte modifiables en ligne ; contenu médical : demande au praticien	Un compte rendu ne se modifie pas, il se complète

Droit	Mise en œuvre	Limite
Effacement	Suppression du compte possible	Les dossiers médicaux sont conservés par obligation légale du praticien
Opposition	Non applicable aux traitements fondés sur le contrat ou l'obligation légale ; applicable aux statistiques	
Portabilité	Export des documents déposés par le patient	
Circuit	Les demandes reçues par Télémédix pour un traitement du client sont transmises au client sous 72 heures (clause contractuelle)	

Sous-traitance (art. 28)

Sous-traitant ultérieur	Contrat	Garanties à obtenir
Hébergeur HDS	Contrat d'hébergement comportant les clauses imposées par le code de la santé publique	Certificat HDS en cours de validité et couvrant les activités réellement fournies ; localisation dans l'EEE
Prestataire visio	Accord de sous-traitance	Chiffrement de bout en bout ou relais dédié ; localisation UE ; notification d'incident sous 24 heures ; droit d'audit
Prestataire de paiement	Accord de sous-traitance	Attestation PCI DSS annuelle
Prestataire de notifications	Accord de sous-traitance	Localisation UE ; suppression des messages après envoi

Les clients sont informés de la liste des sous-traitants ultérieurs et de tout changement, avec un droit d'objection.

3.4 Risques pour les droits et libertés des personnes

Échelle de la CNIL : négligeable, limitée, importante, maximale.

Événement redouté	Impacts pour les personnes	Sources et scénarios (dossier 2)	Gravité	Vraisemblance initiale	Mesures	Vraisemblance résiduelle
Accès illégitime aux données	Révélation de pathologies, discrimination, chantage, atteinte à la réputation, hameçonnage ciblé	R01, R02, R03, R05, R06, R08, R09	Maximale	Importante	A05, A07, A08, A10, A12, A14, A15, A18, A24	Limitée
Modification non désirée	Ordonnance ou compte rendu faux : erreur de prise en charge ; faux documents au nom d'un patient ou d'un praticien	R03, R04	Importante	Importante	A06, A15, A18, A27	Limitée

Événement redouté	Impacts pour les personnes	Sources et scénarios (dossier 2)	Gravité	Vraisemblance initiale	Mesures	Vraisemblance résiduelle
Disparition des données	Perte du dossier, rupture de suivi, consultation impossible	R01, R07	Importante	Importante	A11, A22, A23	Négligeable

Lecture. La gravité d'un accès illégitime reste maximale après traitement : une donnée de santé divulguée ne peut pas être « rattrapée ». Le plan agit sur la vraisemblance. Ce risque résiduel est porté à la connaissance des clients.

3.5 Plan d'action et validation

Élément	Contenu
Mesures à mettre en œuvre	Actions A04, A05, A06, A07, A08, A10, A11, A12, A13, A14, A15, A17, A18, A24 du dossier 6
Avis du DPO	Favorable **sous réserve** : réalisation des actions A07, A08 et A12 sous 4 mois ; qualification HDS de l'activité 5 (A03)
Avis des personnes concernées	À recueillir auprès d'un panel de patients et de praticiens (art. 35.9), ou justification de l'absence de consultation
Consultation préalable de la CNIL (art. 36)	Non requise si le risque résiduel est jugé acceptable après réalisation du plan ; à réexaminer si A10 ou A24 étaient abandonnées
Décision	Compte patient : validation par la direction de Télémédix. Téléconsultation : validation par chaque client
Révision	Tous les 3 ans au plus, et à chaque évolution majeure (enregistrement, nouvelle finalité, nouveau sous-traitant, alimentation du DMP)

3.6 Registre des activités de traitement

Télémédix tient **deux registres** : celui du responsable de traitement (art. 30.1) et celui du sous-traitant (art. 30.2).

Registre du responsable de traitement

Réf.	Traitement	Finalité	Base légale	Personnes	Données	Destinataires	Durée	Sécurité
T01	Compte utilisateur patient	Créer et authentifier le compte, gérer les préférences	Contrat	Patients	D1, identifiants de connexion	Personnel habilité ; hébergeur	3 ans après la dernière connexion	MFA, chiffrement, journalisation
T02	Gestion de la relation client	Contractualisation, facturation des abonnements	Contrat ; obligation légale (comptabilité)	Professionnels, contacts des structures	D6, coordonnées, données de facturation	Finance, commerce	Durée du contrat + 5 ans ; pièces comptables 10 ans	Contrôle d'accès
T03	Support aux utilisateurs	Répondre aux demandes d'assistance	Contrat	Patients, professionnels	D1, D6, contenu des tickets	Support ; éditeur de l'outil de tickets	3 ans ; pièces jointes 90 jours	Accès tracé et justifié (A08)

Réf.	Traitement	Finalité	Base légale	Personnes	Données	Destinataires	Durée	Sécurité
T04	Sécurité et journalisation	Détecter les incidents, tracer les accès, constituer des preuves	Obligation légale	Tous utilisateurs, salariés	D8	RSSI, SRE ; prestataire de supervision	6 à 12 mois	Journaux protégés en intégrité
T05	Statistiques d'usage	Améliorer le produit	Intérêt légitime	Utilisateurs	Données agrégées, sans donnée de santé	Produit	25 mois	Agrégation
T06	Gestion du personnel	Paie, administration	Contrat ; obligation légale	Salariés	Données RH	RH ; prestataire de paie	Selon les obligations sociales	Hors périmètre du dossier

Registre du sous-traitant

Réf.	Catégorie de traitements	Pour le compte de	Données	Sous-traitants ultérieurs	Transferts hors UE	Sécurité
S01	Téléconsultation (visio, audio, messagerie)	Clients	D3, D4	Hébergeur, prestataire visio	Aucun	Chiffrement des flux ; cible : bout en bout (A24)
S02	Tenue du dossier de téléconsultation	Clients	D1, D2, D3	Hébergeur	Aucun	Chiffrement, contrôle d'accès, traces
S03	Prise de rendez-vous et rappels	Clients	D1, D5	Hébergeur, prestataire de notifications	Aucun	Messages sans donnée de santé (A12)
S04	Encaissement des actes	Clients	D7	Prestataire de paiement	Aucun	Redirection, pas de stockage de carte
S05	Hébergement, sauvegarde et restitution	Clients	D1 à D8	Hébergeur	Aucun	Sauvegardes chiffrées et isolées (A11)

Coordonnées à compléter dans la version opérationnelle : identité de chaque client, DPO de Télémédix, DPO des clients qui en ont désigné un.

3.7 Justification des choix (arguments d'entretien)

Choix	Justification
Une AIPD type fournie aux clients	Un médecin libéral n'a pas les moyens de mener seul une AIPD sur une plateforme qu'il ne maîtrise pas ; l'aide du sous-traitant est une obligation, et un argument commercial
Le consentement écarté comme base légale	Un consentement n'est pas libre quand le refus prive de soins, et il serait révocable à tout moment, ce qui est incompatible avec l'obligation de conserver le dossier
Durées fixées par le client	Le sous-traitant ne détermine pas les durées ; il doit en revanche rendre leur application techniquement possible
Gravité maximale maintenue	Cohérent avec l'analyse EBIOS RM : mêmes hypothèses, mêmes conclusions

Choix	Justification
Deux registres	Oubli fréquent : un éditeur SaaS est presque toujours à la fois responsable et sous-traitant

4. Déclaration d'applicabilité ISO/IEC 27001:2022

Document exigé par la clause 6.1.3 d) de la norme : il liste les 93 mesures de l'Annexe A, indique si chacune est retenue, pourquoi, et où en est sa mise en œuvre.

Paramètre	Valeur
Périmètre du SMSI	Conception, développement, administration, exploitation et support de la plateforme Télémédix, hébergée chez un hébergeur certifié HDS
Source des justifications	Risques R01 à R10 de l'étude EBIOS RM (dossier 2), exigences légales et contractuelles
Version	0.1, à valider par la direction
Avertissement	Les intitulés reprennent les titres français usuels des mesures ; ils sont à contrôler sur l'exemplaire officiel de la norme (AFNOR)

Légende de l'état. *En place* : mesure appliquée et vérifiable. *Partiel* : appliquée en partie ou non formalisée. *À faire* : absente. *Exclu* : mesure non retenue. **Colonne Actions** : référence au plan d'actions (dossier 6). Un tiret signifie qu'aucune action n'est nécessaire.

Synthèse

Thème	Mesures	Retenues	Exclues	En place	Partiel	À faire
5. Mesures organisationnelles	37	37	0	1	23	13
6. Mesures liées aux personnes	8	8	0	2	6	0
7. Mesures physiques	14	11	3	6	5	0
8. Mesures technologiques	34	33	1	1	26	6
Total	**93**	**89**	**4**	**10**	**60**	**19**

Exclusions

Mesure	Justification de l'exclusion
7.6 Travail dans les zones sécurisées	Télémédix n'exploite aucune zone sécurisée : toute l'infrastructure de production est dans les centres de données de l'hébergeur, dont la sécurité physique est couverte par son certificat HDS (activité 1) et suivie par les mesures 5.19 à 5.23
7.11 Services supports	Alimentation électrique et climatisation relèvent de l'hébergeur ; les bureaux n'hébergent aucun traitement de production
7.12 Sécurité du câblage	Aucune infrastructure réseau de production dans les locaux ; le réseau des bureaux est traité comme un réseau non sûr (accès à la production par VPN et bastion uniquement)

Mesure	Justification de l'exclusion
8.30 Développement externalisé	Tout le développement est réalisé par des salariés ; à réintégrer dès le premier recours à un prestataire de développement

5. Mesures organisationnelles

Réf.	Mesure	Retenue	Justification	État	Actions
5.1	Politiques de sécurité de l'information	Oui	Socle de tous les risques R01 à R10 ; exigée par HDS et par NIS2 (art. 21.2.a)	À faire	A01
5.2	Fonctions et responsabilités liées à la sécurité de l'information	Oui	Tous risques ; RSSI à mi-temps sans lettre de mission	Partiel	A01
5.3	Séparation des tâches	Oui	R03, R06 : un même SRE développe, déploie et administre	Partiel	A09, A15
5.4	Responsabilités de la direction	Oui	Tous risques ; NIS2 art. 20 (responsabilité des dirigeants)	Partiel	A01, A02
5.5	Contacts avec les autorités	Oui	R01, R07 ; notification CNIL sous 72 h (RGPD art. 33)	À faire	A22
5.6	Contacts avec des groupes d'intérêt spécifiques	Oui	R01, R02 : veille CERT-FR et CERT Santé	Partiel	A20
5.7	Renseignement sur les menaces	Oui	R01, R02, R05 : anticiper les campagnes visant la santé	À faire	A18, A20
5.8	Sécurité de l'information dans la gestion de projet	Oui	R02, R03 : la sécurité doit être traitée dès la conception	Partiel	A14
5.9	Inventaire des informations et autres actifs associés	Oui	Tous risques ; base de l'atelier 1	Partiel	A02
5.10	Utilisation correcte des informations et autres actifs associés	Oui	R06, R09	Partiel	A01
5.11	Restitution des actifs	Oui	R06 : départs de salariés	En place	-
5.12	Classification des informations	Oui	R06, R09 : échelle C1 à C4 définie au dossier 1, non appliquée	À faire	A02
5.13	Marquage des informations	Oui	R09	À faire	A02
5.14	Transfert des informations	Oui	R08, R09 : notifications, tickets, flux vers les tiers	Partiel	A12
5.15	Contrôle d'accès	Oui	R01, R02, R04, R05, R06	Partiel	A05, A09
5.16	Gestion des identités	Oui	R04, R05, R06 ; identité des professionnels (Pro Santé Connect)	Partiel	A06, A09
5.17	Informations d'authentification	Oui	R01, R04, R05	Partiel	A05, A07
5.18	Droits d'accès	Oui	R01, R06	Partiel	A08, A09
5.19	Sécurité de l'information dans les relations avec les fournisseurs	Oui	R03, R07, R08, R09, R10	Partiel	A25
5.20	Sécurité de l'information dans les accords conclus avec les fournisseurs	Oui	R08, R09, R10 ; RGPD art. 28 ; clauses HDS	Partiel	A24, A25
5.21	Gestion de la sécurité de l'information dans la chaîne d'approvisionnement TIC	Oui	R03 : dépendances logicielles en zone de danger	À faire	A15, A25

Réf.	Mesure	Retenue	Justification	État	Actions
5.22	Surveillance, révision et gestion des changements des services fournisseurs	Oui	R07, R08	À faire	A25
5.23	Sécurité de l'information dans l'utilisation de services en nuage	Oui	R01, R07 ; partage des responsabilités avec l'hébergeur, qualification HDS	Partiel	A03, A25
5.24	Planification et préparation de la gestion des incidents	Oui	R01, R07 et tous risques	À faire	A22
5.25	Évaluation des événements de sécurité et prise de décision	Oui	R01, R02, R05	À faire	A18, A22
5.26	Réponse aux incidents de sécurité de l'information	Oui	R01	Partiel	A22
5.27	Tirer des enseignements des incidents	Oui	Tous risques ; amélioration continue	À faire	A22
5.28	Collecte des preuves	Oui	R01, R06 : dépôt de plainte, contentieux	À faire	A18, A22
5.29	Sécurité de l'information pendant une perturbation	Oui	R01, R07	À faire	A23
5.30	Préparation des TIC pour la continuité d'activité	Oui	R01, R07	Partiel	A11, A23
5.31	Exigences légales, statutaires, réglementaires et contractuelles	Oui	RGPD, code de la santé publique (HDS), NIS2	Partiel	A03, A04, A28
5.32	Droits de propriété intellectuelle	Oui	R03 : licences des dépendances open source	Partiel	A15
5.33	Protection des enregistrements	Oui	R01 ; durées de conservation des dossiers et des traces	Partiel	A11, A13
5.34	Protection de la vie privée et des données à caractère personnel	Oui	R02, R06, R09 ; RGPD	Partiel	A04, A13
5.35	Revue indépendante de la sécurité de l'information	Oui	Tous risques ; seul un test d'intrusion annuel existe	Partiel	A02, A16
5.36	Conformité aux politiques, règles et normes de sécurité	Oui	Tous risques	À faire	A02
5.37	Procédures d'exploitation documentées	Oui	R01, R07 ; exigé pour l'activité 5 HDS	Partiel	A02

6. Mesures liées aux personnes

Réf.	Mesure	Retenue	Justification	État	Actions
6.1	Sélection des candidats	Oui	R06 : postes à privilèges	Partiel	A09
6.2	Termes et conditions du contrat de travail	Oui	R06 : clause de confidentialité et de secret	En place	-
6.3	Sensibilisation, enseignement et formation	Oui	R01, R04, R06	Partiel	A26
6.4	Processus disciplinaire	Oui	R06	Partiel	A01
6.5	Responsabilités après la fin ou le changement d'un emploi	Oui	R01, R06	Partiel	A09
6.6	Accords de confidentialité ou de non-divulgation	Oui	R06, R09	En place	-
6.7	Travail à distance	Oui	R01 : télétravail des administrateurs	Partiel	A05, A19

Réf.	Mesure	Retenue	Justification	État	Actions
6.8	Déclaration des événements de sécurité	Oui	R01, R06	Partiel	A22, A26

7. Mesures physiques

Réf.	Mesure	Retenue	Justification	État	Actions
7.1	Périmètres de sécurité physique	Oui	R06 : bureaux ; centres de données couverts par l'hébergeur	En place	-
7.2	Les entrées physiques	Oui	R06 : contrôle d'accès par badge	En place	-
7.3	Sécurisation des bureaux, des salles et des installations	Oui	R06	En place	-
7.4	Surveillance de la sécurité physique	Oui	R06 : alarme et vidéosurveillance de l'immeuble	En place	-
7.5	Protection contre les menaces physiques et environnementales	Oui	R07 : deux sites distincts chez l'hébergeur	En place	-
7.6	Travail dans les zones sécurisées	Non	Voir exclusions	Exclu	-
7.7	Bureau vide et écran vide	Oui	R06, R09 : support en espace ouvert	Partiel	A01, A26
7.8	Emplacement et protection du matériel	Oui	R01 : postes de travail	En place	-
7.9	Sécurité des actifs hors des locaux	Oui	R01, R06 : portables en télétravail	Partiel	A19
7.10	Supports de stockage	Oui	R06, R09 : supports amovibles	Partiel	A19
7.11	Services supports	Non	Voir exclusions	Exclu	-
7.12	Sécurité du câblage	Non	Voir exclusions	Exclu	-
7.13	Maintenance du matériel	Oui	R09 : postes envoyés en réparation	Partiel	A19
7.14	Élimination ou recyclage sécurisé(e) du matériel	Oui	R09	Partiel	A13

8. Mesures technologiques

Réf.	Mesure	Retenue	Justification	État	Actions
8.1	Terminaux finaux des utilisateurs	Oui	R01, R03 : poste compromis d'un SRE ou d'un développeur	Partiel	A19
8.2	Droits d'accès privilégiés	Oui	R01, R03, R06	Partiel	A05, A08
8.3	Restriction d'accès aux informations	Oui	R02, R06	Partiel	A08, A14
8.4	Accès aux codes source	Oui	R03	Partiel	A15
8.5	Authentification sécurisée	Oui	R01, R04, R05	Partiel	A05, A06, A07

Réf.	Mesure	Retenue	Justification	État	Actions
8.6	Dimensionnement	Oui	R07	Partiel	A23
8.7	Protection contre les programmes malveillants	Oui	R01	Partiel	A19
8.8	Gestion des vulnérabilités techniques	Oui	R01, R02	Partiel	A16, A20
8.9	Gestion des configurations	Oui	R01, R02	Partiel	A20, A21
8.10	Suppression des informations	Oui	R09 ; RGPD art. 5.1.e et 17	À faire	A13
8.11	Masquage des données	Oui	R06, R09 : journaux, tickets, recette	À faire	A12, A17
8.12	Prévention de la fuite de données	Oui	R01, R02, R06 : détection des exfiltrations	À faire	A18, A21
8.13	Sauvegarde des informations	Oui	R01, R07	Partiel	A11
8.14	Redondance des moyens de traitement de l'information	Oui	R07	Partiel	A23
8.15	Journalisation	Oui	R02, R05, R06 ; traçabilité exigée par la PGSSI-S	Partiel	A18
8.16	Activités de surveillance	Oui	R01, R02, R04, R05	À faire	A18, A27
8.17	Synchronisation des horloges	Oui	R06 : valeur probante des traces	En place	-
8.18	Utilisation de programmes utilitaires à privilèges	Oui	R01	Partiel	A05, A19
8.19	Installation de logiciels sur des systèmes opérationnels	Oui	R01, R03	Partiel	A15
8.20	Sécurité des réseaux	Oui	R01, R07	Partiel	A21
8.21	Sécurité des services réseau	Oui	R07, R08	Partiel	A21, A24
8.22	Cloisonnement des réseaux	Oui	R01, R02 : limiter la propagation	Partiel	A17, A21
8.23	Filtrage web	Oui	R01 : flux sortants des serveurs et des postes	À faire	A19, A21
8.24	Utilisation de la cryptographie	Oui	R01, R02, R08	Partiel	A10, A24
8.25	Cycle de vie de développement sécurisé	Oui	R02, R03	Partiel	A14, A15
8.26	Exigences de sécurité des applications	Oui	R02, R04, R05	Partiel	A14
8.27	Principes d'ingénierie et d'architecture des systèmes sécurisés	Oui	R01, R02	Partiel	A10, A21
8.28	Codage sécurisé	Oui	R02	Partiel	A14, A26
8.29	Tests de sécurité dans le développement et l'acceptation	Oui	R02, R03	Partiel	A15, A16
8.30	Développement externalisé	Non	Voir exclusions	Exclu	-
8.31	Séparation des environnements de développement, de test et opérationnels	Oui	R02, R03, R06	Partiel	A17
8.32	Gestion des changements	Oui	R03, R07	Partiel	A15

Réf.	Mesure	Retenue	Justification	État	Actions
8.33	Informations de test	Oui	R06, R09 : données de production en recette	À faire	A17
8.34	Protection des systèmes d'information pendant les tests d'audit	Oui	R07 : tests d'intrusion en production	Partiel	A16

Justification des choix (arguments d'entretien)

Choix	Justification
Seulement 4 exclusions	Une exclusion doit être justifiée par l'absence du risque, pas par l'absence de la mesure. Trop d'exclusions réduisent la valeur du certificat et attirent l'attention de l'auditeur
Mesures physiques conservées pour les bureaux	Les postes des administrateurs et du support donnent accès à la production : les locaux font partie de la surface d'attaque (R06)
Chaque mesure reliée à un risque	La norme demande que les mesures découlent du traitement des risques (clause 6.1.3) ; l'Annexe A sert de liste de contrôle, pas de point de départ
Beaucoup de « Partiel »	État honnête d'une structure qui a de bonnes pratiques techniques mais peu de preuves ; l'auditeur évalue des preuves
Mesures non rattachées à un risque EBIOS	Quelques mesures (5.31, 5.32, 5.34) sont d'abord justifiées par une obligation légale : c'est admis et doit être dit

5. Applicabilité et matrices d'écarts HDS et NIS2

> État du droit arrêté au **11 novembre 2026**. Les deux sujets évoluent : chaque affirmation datée est à revérifier avant un entretien (liste en annexe).

5.1 HDS : à qui s'applique l'obligation ?

Règle

L'article L.1111-8 du code de la santé publique impose une certification à toute personne qui héberge, **pour le compte d'un tiers**, des données de santé recueillies à l'occasion d'activités de prévention, de diagnostic, de soins ou de suivi. Le code liste six activités d'hébergement ; chaque acteur doit être certifié pour les activités qu'il réalise effectivement.

N°	Activité	Qui la réalise dans le cas Télémédix	Certifié ?
1	Mise à disposition et maintien en condition opérationnelle des sites physiques	Hébergeur	Oui
2	Mise à disposition et maintien en condition opérationnelle de l'infrastructure matérielle	Hébergeur	Oui
3	Mise à disposition et maintien en condition opérationnelle de l'infrastructure virtuelle	Hébergeur	Oui
4	Mise à disposition et maintien en condition opérationnelle de la plateforme d'hébergement d'applications	Non fournie comme service : Télémédix installe et exploite elle-même systèmes et intergiciels sur les VM	Sans objet, à confirmer
5	Administration et exploitation du système d'information contenant les données de santé	**Télémédix** (équipe SRE)	**Non**
6	Sauvegarde des données de santé	Hébergeur (service de sauvegarde), piloté par Télémédix	Oui

Argumentation

1. **Les clients sont les « tiers » protégés par le texte.** Médecins et structures de santé confient les données de leurs patients à Télémédix : Télémédix héberge pour leur compte, même si elle s'appuie sur un hébergeur.
2. **« L'exigence HDS porte sur l'hébergeur » est une demi-vérité.** Elle porte sur chaque acteur qui réalise une des six activités. Le certificat de l'hébergeur couvre les activités 1, 2, 3 et 6. Il ne couvre pas ce que fait Télémédix.
3. **Télémédix réalise l'activité 5.** Ses SRE disposent d'accès d'administration aux systèmes et aux bases qui contiennent les données de santé, déploient, supervisent et interviennent en production. Le référentiel v2 définit l'activité 5 comme la maîtrise des interventions sur les ressources mises à disposition

du client.

4. **Conclusion : écart majeur.** Télémédix doit soit obtenir la certification HDS pour l'activité 5 (ce qui suppose un SMSI certifié ISO 27001 sur ce périmètre), soit confier l'administration et l'exploitation à un infogérant certifié et ne conserver aucun accès aux données.
5. **Le prestataire visio.** Les flux ne sont pas conservés ; un simple transit ne semble pas constituer un hébergement, mais la question mérite une vérification, surtout tant que le flux est déchiffré sur ses serveurs. Le chiffrement de bout en bout (A24) règle le sujet sur le fond.

Réserve. La frontière de l'activité 5 pour les éditeurs fait l'objet de travaux pédagogiques de l'ANS en cours (FAQ, cas d'usage types). La qualification retenue ici est la lecture prudente ; elle doit être confirmée sur la FAQ de l'ANS et, pour un cas réel, par un avis juridique (action A03).

Trajectoire recommandée

Option	Avantages	Inconvénients	Décision proposée
A. Certification HDS activité 5 par Télémédix	Maîtrise de l'exploitation ; argument commercial fort ; réutilise le SMSI ISO 27001	12 à 18 mois ; coût d'audit et de maintien ; effort documentaire	**Retenue** (A02)
B. Infogérance par un prestataire certifié activité 5	Mise en conformité plus rapide	Perte d'agilité (les développeurs ne touchent plus la production) ; coût récurrent ; dépendance	Solution de repli ou transitoire
C. Statu quo	Aucun coût immédiat	Non-conformité à une obligation légale ; perte d'appels d'offres hospitaliers	Écartée

5.2 Matrice d'écarts HDS

Les exigences sont regroupées par thème. Les numéros d'exigence du référentiel v2 sont à reporter depuis le texte officiel lors de la revue : ils ne sont volontairement pas reproduits de mémoire.

Volet 1 : ce que Télémédix doit vérifier chez son hébergeur

Thème	Attendu	Constat	Écart	Actions
Validité du certificat	Certificat en cours de validité, délivré selon le référentiel v2	Certificat présenté à la signature, jamais recontrôlé	Mineur	A25
Périmètre du certificat	Les activités certifiées couvrent tous les services réellement utilisés (VM, stockage, sauvegarde)	Activités 1, 2, 3 et 6 ; correspondance avec les services consommés non vérifiée ligne à ligne	Mineur	A25
Localisation	Données stockées dans l'Espace économique européen	Deux sites en France	Aucun	-
Accès depuis un pays tiers et législations extra-européennes	Information du client sur les accès distants hors EEE et sur les législations étrangères applicables à l'hébergeur	Information non demandée	Mineur	A25
Contrat d'hébergement	Clauses imposées par le code de la santé publique (périmètre, localisation, réversibilité, sous-traitants, qualité de service)	Contrat standard de l'hébergeur ; revue juridique non faite	Mineur	A03, A25
Sous-traitants de l'hébergeur	Liste communiquée ; sous-traitants eux-mêmes couverts	Liste non demandée	Mineur	A25

Thème	Attendu	Constat	Écart	Actions
Réversibilité	Restitution des données dans un format exploitable, puis destruction	Clause présente, jamais testée	Mineur	A23

Volet 2 : ce que Télémédix doit satisfaire pour l'activité 5

Thème	Attendu	Constat	Écart	Actions
Certification	Certificat HDS couvrant l'activité 5	Absent	**Majeur**	A02, A03
Système de management	SMSI conforme à l'ISO 27001 sur le périmètre d'hébergement ; déclaration d'applicabilité	Pas de SMSI ; déclaration d'applicabilité en version 0.1 (dossier 4)	**Majeur**	A01, A02
Analyse de risques	Appréciation des risques couvrant les données de santé	Étude EBIOS RM réalisée (dossier 2)	Aucun	-
Maîtrise des accès d'administration	Comptes nominatifs, authentification forte, traçabilité des interventions	MFA partiel, traces non centralisées	**Majeur**	A05, A18
Accès aux données par le personnel	Accès limités au strict nécessaire, justifiés et revus	Connexion « en tant que » sans contrôle	**Majeur**	A08, A09
Chiffrement	Protection des données de santé en transit et au repos	Disques chiffrés ; pas de chiffrement applicatif	Mineur	A10
Sauvegarde et continuité	Sauvegardes testées ; plan de continuité	Restauration jamais testée ; PRA non testé	**Majeur**	A11, A23
Gestion des incidents	Procédure, information du client sans délai	Pas de procédure formalisée	**Majeur**	A22
Relations avec les clients	Contrat conforme : description des prestations, localisation, sous-traitants ultérieurs, réversibilité, engagements de service	Conditions générales incomplètes sur ces points	Mineur	A03, A04
Sous-traitance ultérieure	Chaîne de sous-traitance maîtrisée et transparente	Trois sous-traitants sous contrat ; pas d'évaluation périodique	Mineur	A25
Souveraineté	Aucun accès aux données depuis un pays tiers sans encadrement ; transparence	Équipes en France ; outils SaaS de support et de CI/CD à qualifier	Mineur	A25
Audit et amélioration	Audits internes, revue de direction	Absents	**Majeur**	A02

Bilan HDS. 7 écarts majeurs, tous sur le volet 2. Le choix de l'hébergeur n'est pas le problème : c'est l'activité propre de l'éditeur qui n'est pas couverte.

5.3 NIS2 : Télémédix est-elle concernée ?

État de la transposition en France

Date	Fait
17 octobre 2024	Échéance de transposition fixée par la directive (UE) 2022/2555
12 mars 2025	Adoption par le Sénat du projet de loi « résilience des infrastructures critiques et renforcement de la cybersécurité »
10 septembre 2025	Adoption du texte par la commission spéciale de l'Assemblée nationale
17 mars 2026	Publication par l'ANSSI du Référentiel Cyber France (ReCyF), en document de travail
8 juillet 2026	Saisine de la Cour de justice de l'UE par la Commission pour défaut de transposition
9 au 13 novembre 2026	Examen du projet de loi en séance publique à l'Assemblée nationale
11 novembre 2026	**Loi non promulguée, aucun décret d'application**

Conséquence. À la date du dossier, aucune obligation NIS2 n'est opposable à une entreprise privée en France. Le raisonnement ci-dessous s'appuie donc sur la directive ; il devra être repris sur la loi promulguée et ses décrets, qui peuvent préciser les catégories et les seuils.

Raisonnement d'applicabilité

Étape	Question	Analyse pour Télémédix	Résultat
1. Taille	L'entité atteint-elle la taille d'une entreprise moyenne (recommandation 2003/361/CE) ?	Une petite entreprise compte moins de 50 personnes **et** un chiffre d'affaires ou un bilan n'excédant pas 10 M€. Avec 52 salariés, Télémédix n'est plus une petite entreprise	**Entreprise moyenne**
2a. Secteur « santé » (annexe I)	Télémédix est-elle un prestataire de soins de santé ?	Non : elle n'emploie aucun professionnel de santé et ne dispense aucun soin. Ses clients, eux, en sont	Non
2b. Secteur « infrastructure numérique » (annexe I)	Télémédix est-elle un fournisseur de services d'informatique en nuage ?	La directive définit ce service comme l'accès à la demande à un ensemble modulable de ressources informatiques partageables. Un logiciel fourni en mode SaaS peut entrer dans cette définition	**Probable, à confirmer**
2c. Secteur « gestion des services TIC » (annexe I)	Télémédix est-elle un fournisseur de services gérés ?	Non : elle exploite sa propre plateforme, pas les systèmes de ses clients	Non
3. Catégorie	Essentielle ou importante ?	Une entité de l'annexe I de taille moyenne est **importante** ; elle devient essentielle au-delà des seuils de l'entreprise moyenne (250 personnes ou plus, ou plus de 50 M€ de chiffre d'affaires et plus de 43 M€ de bilan)	**Entité importante**
4. Effet indirect	Les clients sont-ils concernés ?	Le centre hospitalier client est un prestataire de soins : il devra maîtriser sa chaîne d'approvisionnement (art. 21.2.d) et répercutera des exigences par contrat	**Oui, dans tous les cas**

Conclusion argumentée

Hypothèse	Qualification	Probabilité estimée
Le SaaS de Télémédix est qualifié de service d'informatique en nuage	**Entité importante**	La plus probable au regard de la directive
Le SaaS n'est pas qualifié ainsi par le droit français	Hors périmètre direct, mais soumise aux exigences contractuelles de ses clients	Possible
Entité essentielle	Écartée : Télémédix n'est ni un prestataire de soins, ni une grande entreprise	Très faible

Position retenue : se préparer comme une entité importante. Trois raisons : la qualification la plus probable y conduit ; les clients hospitaliers l'exigeront par contrat de toute façon ; les mesures attendues recoupent presque entièrement l'ISO 27001 et le référentiel HDS, déjà visés.

Sensibilité au seuil. Avec 48 salariés, Télémédix serait une petite entreprise et sortirait du périmètre direct, sauf désignation particulière. Le calcul de l'effectif intègre les entreprises liées et partenaires : une filiale ou un actionnaire majoritaire peut faire franchir le seuil.

Texte complémentaire. Pour les fournisseurs de services numériques, dont l'informatique en nuage, la Commission a adopté le règlement d'exécution (UE) 2024/2690, qui détaille les mesures techniques attendues et les critères d'incident important. Son articulation avec le référentiel de l'ANSSI est à vérifier.

5.4 Matrice d'écarts NIS2

Référence : directive (UE) 2022/2555, articles 20, 21 et 23. Correspondance indicative avec l'Annexe A de l'ISO 27001:2022.

Exigence	Attendu	Constat	Écart	Mesures ISO liées	Actions
Art. 20 : gouvernance	Les dirigeants approuvent les mesures, en supervisent la mise en œuvre et se forment	Sécurité non portée en comité de direction	**Majeur**	5.1, 5.4	A01, A26
Art. 21.2.a : politiques d'analyse des risques et de sécurité	Analyse de risques et politique formalisées	Étude EBIOS RM réalisée ; PSSI rédigée, non approuvée	Mineur	5.1	A01
Art. 21.2.b : gestion des incidents	Détection, traitement, retour d'expérience	Pas de procédure ni de détection centralisée	**Majeur**	5.24 à 5.28, 8.15, 8.16	A18, A22
Art. 21.2.c : continuité, sauvegardes, gestion de crise	Sauvegardes, reprise, cellule de crise testées	Sauvegardes non testées ; PRA non testé ; pas d'exercice	**Majeur**	5.29, 5.30, 8.13, 8.14	A11, A22, A23
Art. 21.2.d : sécurité de la chaîne d'approvisionnement	Évaluation et encadrement contractuel des fournisseurs	Contrats signés, pas de suivi	**Majeur**	5.19 à 5.23	A15, A24, A25

Exigence	Attendu	Constat	Écart	Mesures ISO liées	Actions
Art. 21.2.e : sécurité de l'acquisition, du développement et de la maintenance ; vulnérabilités	Développement sécurisé, gestion et divulgation des vulnérabilités	Revue de code ; pas d'outillage ni de délais de correction	**Majeur**	8.8, 8.25 à 8.29	A14, A15, A16, A20
Art. 21.2.f : évaluation de l'efficacité des mesures	Indicateurs, audits, tests	Test d'intrusion annuel seulement	Mineur	5.35, 5.36	A02, A16
Art. 21.2.g : cyberhygiène et formation	Pratiques de base et formation régulière	Session d'accueil uniquement	Mineur	6.3, 8.1, 8.7	A19, A26
Art. 21.2.h : cryptographie et chiffrement	Politique de chiffrement et de gestion des clés	Chiffrement en place, pas de politique ; pas de chiffrement applicatif	Mineur	8.24	A10, A24
Art. 21.2.i : ressources humaines, contrôle d'accès, gestion des actifs	Habilitations, revues, inventaire	Revue des droits absente ; inventaire partiel	Mineur	5.9, 5.15 à 5.18, 6.1 à 6.6	A08, A09
Art. 21.2.j : authentification multifacteur, communications sécurisées	MFA et canaux de secours sécurisés	MFA partiel ; pas de canal de crise hors bande	**Majeur**	5.14, 8.5	A05, A06, A07, A22
Art. 23 : notification des incidents importants	Alerte sous 24 heures, notification sous 72 heures, rapport final sous un mois	Aucune procédure	**Majeur**	5.5, 5.24, 5.26	A22
Enregistrement auprès de l'autorité	Déclaration de l'entité selon les modalités nationales	Sans objet tant que la loi n'est pas en vigueur	En attente	5.31	A28

Bilan NIS2. 7 écarts majeurs sur 13 exigences. Tous sont déjà couverts par des actions issues de l'analyse de risques : NIS2 n'ajoute aucun chantier technique, elle ajoute la responsabilité des dirigeants (art. 20) et les délais de notification (art. 23).

5.5 Recouvrement des référentiels

Sujet	RGPD	HDS	ISO 27001	NIS2
Analyse de risques	Art. 32, 35	Oui	Clause 6.1	Art. 21.2.a
Notification d'incident	CNIL sous 72 h (art. 33) ; le sous-traitant prévient le responsable sans délai	Information du client	5.24 à 5.26	24 h, 72 h, un mois (art. 23)
Sous-traitance	Art. 28	Chaîne certifiée et transparente	5.19 à 5.23	Art. 21.2.d
Responsabilité de la direction	Responsabilité (art. 5.2, 24)	Via le SMSI	Clause 5	Art. 20
Certification	Non	Oui	Oui (volontaire)	Non

Lecture. Un seul système de management (ISO 27001) alimenté par une seule analyse de risques (EBIOS RM) permet de répondre aux quatre cadres. C'est la justification de l'action structurante A02.

5.6 Justification des choix (arguments d'entretien)

Choix	Justification
Qualifier l'éditeur pour l'activité 5	Lecture conforme à la règle « chaque acteur est certifié pour ce qu'il fait ». Soutenir l'inverse expose à un refus en appel d'offres et à un risque pénal
Ne pas citer les numéros d'exigence HDS	Citer de mémoire un numéro faux décrédibilise tout le dossier ; la colonne est à remplir texte en main
Raisonner sur la directive	Seul texte stable à la date du dossier ; la loi française pouvait encore être amendée
Conclure « entité importante probable » plutôt que trancher	La qualification du SaaS comme informatique en nuage est discutée ; un consultant annonce son niveau de certitude
Écarter « entité essentielle »	Confusion fréquente : la santé est un secteur hautement critique, mais l'éditeur n'est pas le prestataire de soins, et la taille compte

6. Plan d'actions priorisé

Le plan regroupe les mesures issues de l'analyse de risques (dossier 2), de l'AIPD (dossier 3), de la déclaration d'applicabilité (dossier 4) et des matrices d'écarts (dossier 5). Chaque action est identifiée de A01 à A28 et utilisée sous ce même identifiant dans tous les dossiers.

Méthode de priorisation

Note	Impact	Effort
1	Amélioration marginale	Moins de 10 jours-homme, sans achat
2	Réduit un risque moyen ou corrige un écart mineur	10 à 40 jours-homme, ou achat inférieur à 10 k€
3	Réduit un risque élevé de gravité G3, ou plusieurs risques moyens	40 à 120 jours-homme, ou achat de 10 à 50 k€
4	Réduit un risque élevé de gravité G4, ou conditionne une conformité légale	Plus de 120 jours-homme, ou achat supérieur à 50 k€

Quadrant	Règle	Traitement
Gain rapide	Impact ≥ 3 et effort ≤ 2	À lancer immédiatement
Projet structurant	Impact ≥ 3 et effort ≥ 3	À planifier avec un budget et un chef de projet
Complément	Impact ≤ 2 et effort ≤ 2	À intégrer au fil de l'eau
À arbitrer	Impact ≤ 2 et effort ≥ 3	À justifier ou à abandonner (aucune action dans ce cas)

L'échéance est exprimée en mois à partir de la validation du plan (M0).

Tableau des actions

ID	Action	Risques couverts	Impact	Effort	Quadrant	Échéance	Pilote	Indicateur de réussite
A01	Approuver la PSSI en comité de direction ; lettre de mission du RSSI avec accès direct au DG ; comité sécurité trimestriel	Tous	3	1	Gain rapide	M1	DG	PSSI signée ; 4 comités par an
A02	Déployer le SMSI ISO 27001 (inventaire, classification, procédures, audit interne, revue de direction) et obtenir les certifications ISO 27001 et HDS activité 5	Tous	4	4	Projet structurant	M18	RSSI	Certificats obtenus

ID	Action	Risques couverts	Impact	Effort	Quadrant	Échéance	Pilote	Indicateur de réussite
A03	Qualifier le périmètre HDS (FAQ de l'ANS, avis juridique), arrêter la trajectoire, mettre à jour les contrats clients et hébergeur	Conformité HDS	4	1	Gain rapide	M2	DG	Décision formalisée ; contrats revus
A04	Finaliser registres et AIPD ; diffuser l'AIPD type aux clients ; procédure de violation de données (72 h) ; mise à jour des accords de sous-traitance	R09	3	2	Gain rapide	M3	DPO	AIPD validée ; procédure testée
A05	MFA résistant à l'hameçonnage (clés FIDO2) sur tous les accès d'administration : console de l'hébergeur, bastion, dépôt, CI/CD, outils SaaS ; comptes nominatifs ; jetons à durée courte	R01, R03	4	1	Gain rapide	M1	Responsable SRE	100 % des comptes à privilèges sous MFA
A06	Authentification des professionnels par Pro Santé Connect ; MFA obligatoire en solution de repli	R04	4	3	Projet structurant	M6	Responsable développement	100 % des connexions de professionnels à deux facteurs
A07	MFA pour les patients avant tout accès à un document médical ; protection contre le test d'identifiants (limitation de débit, refus des mots de passe compromis, alerte de connexion inhabituelle)	R05	3	2	Gain rapide	M4	Responsable développement	Taux de comptes sous MFA ; tentatives bloquées
A08	Encadrer la connexion « en tant que » : justification obligatoire, durée limitée, notification de l'utilisateur, trace dédiée, revue mensuelle	R06	3	2	Gain rapide	M4	Responsable support	100 % des accès justifiés et revus
A09	Revue trimestrielle des droits ; procédure d'arrivée, de mobilité et de départ ; vérifications à l'embauche pour les postes à privilèges ; séparation des rôles	R06	2	1	Complément	M3	RSSI	Revues réalisées ; comptes orphelins = 0
A10	Chiffrement applicatif des documents médicaux avec une clé par client, gérée dans un service de gestion de clés ; rotation	R01, R02, R06	4	3	Projet structurant	M9	Responsable développement	100 % des documents chiffrés
A11	Sauvegardes immuables dans un compte séparé (règle 3-2-1) ; test de restauration trimestriel ; RPO de 1 heure et RTO de 4 heures formalisés	R01, R07	4	2	Gain rapide	M3	Responsable SRE	Restauration réussie chaque trimestre
A12	Supprimer les données de santé des canaux secondaires : messages génériques, masquage dans les journaux, purge des pièces jointes des tickets, libellé bancaire neutre	R09, R10	2	1	Complément	M2	Directeur produit	Contrôle par échantillonnage : 0 donnée de santé
A13	Automatiser les durées de conservation : comptes inactifs, journaux, tickets, restitution et suppression en fin de contrat ; effacement sécurisé des matériels	R09	2	2	Complément	M6	Responsable développement	Purges exécutées et tracées

ID	Action	Risques couverts	Impact	Effort	Quadrant	Échéance	Pilote	Indicateur de réussite
A14	Contrôle d'autorisation systématique sur chaque objet de l'API ; tests automatisés d'autorisation dans la CI ; exigences de sécurité dès la conception (référentiel OWASP ASVS)	R02	4	2	Gain rapide	M3	Responsable développement	100 % des points d'accès couverts par un test d'autorisation
A15	Sécuriser la chaîne logicielle : analyse du code, des dépendances et des secrets dans la CI ; inventaire des composants (SBOM) ; versions figées ; artefacts signés ; branches protégées avec double validation	R03	4	2	Gain rapide	M4	Responsable développement	0 vulnérabilité critique non traitée en production
A16	Test d'intrusion immédiat (le dernier date de 14 mois), puis annuel et après tout changement majeur ; politique de divulgation des vulnérabilités	R02, R04, R05	3	2	Gain rapide	M2	RSSI	Rapport reçu ; corrections critiques sous 30 jours
A17	Séparer strictement les environnements ; données de test synthétiques ; aucune donnée de production en recette	R02, R06	3	2	Gain rapide	M5	Responsable développement	0 donnée réelle hors production
A18	Centraliser les journaux et les traces d'accès ; règles de détection alignées sur R01 à R06 ; supervision externalisée ; conservation de 12 mois	R01, R02, R05, R06	4	3	Projet structurant	M8	RSSI	Délai de détection ; scénarios couverts
A19	EDR sur les postes et les serveurs ; poste d'administration dédié ; blocage des supports amovibles ; effacement avant réparation	R01, R03	3	2	Gain rapide	M4	Responsable SRE	100 % du parc couvert
A20	Gestion des vulnérabilités : analyse hebdomadaire, veille CERT-FR et CERT Santé, délais de correction (7 jours pour une vulnérabilité critique, 48 heures si elle est exploitée)	R01, R02	3	2	Gain rapide	M3	Responsable SRE	Respect des délais ≥ 95 %
A21	Cloisonner le réseau de production ; filtrer les flux sortants ; pare-feu applicatif et protection anti-DDoS	R01, R02, R07	3	3	Projet structurant	M6	Responsable SRE	Matrice de flux appliquée ; test de charge réussi
A22	Plan de réponse aux incidents ; cellule de crise et canal de communication de secours ; modèles de notification (clients, CNIL, autorité NIS2) ; exercice annuel	R01, R07	4	2	Gain rapide	M4	RSSI	Exercice réalisé ; notification simulée sous 24 h
A23	Plan de continuité et de reprise testé chaque année ; bascule sur le second site ; mode dégradé par téléphone si la visio est indisponible ; test de réversibilité	R07	3	3	Projet structurant	M9	Responsable SRE	RTO mesuré ≤ 4 h
A24	Visio : chiffrement de bout en bout, ou relais dédiés hébergés sur l'infrastructure HDS ; clauses renforcées ; plan de sortie	R07, R08	3	3	Projet structurant	M9	CTO	Flux illisible par le prestataire
A25	Gestion des tiers : évaluation annuelle, collecte des certificats (HDS, ISO 27001, PCI DSS), clauses de sécurité et de notification, registre des sous-traitants ultérieurs	R03, R07, R08, R09, R10	3	2	Gain rapide	M5	RSSI	100 % des tiers critiques évalués

ID	Action	Risques couverts	Impact	Effort	Quadrant	Échéance	Pilote	Indicateur de réussite
A26	Sensibilisation continue ; simulations d'hameçonnage ; formation des dirigeants ; développement sécurisé ; secret médical pour le support	R01, R06	3	1	Gain rapide	M3	RSSI	Participation ≥ 90 % ; taux de clic en baisse
A27	Protéger les clients : guide de sécurité pour les cabinets, alerte de connexion inhabituelle, détection des volumes anormaux d'ordonnances et d'arrêts de travail	R04	3	2	Gain rapide	M6	Directeur produit	Alertes traitées sous 24 h
A28	Veille sur la loi de transposition de NIS2 et ses décrets ; auto-qualification ; analyse d'écart avec le référentiel de l'ANSSI ; enregistrement le moment venu	Conformité NIS2	2	1	Complément	M2	RSSI	Note de qualification à jour

Synthèse

Quadrant	Nombre	Actions
Gain rapide	17	A01, A03, A04, A05, A07, A08, A11, A14, A15, A16, A17, A19, A20, A22, A25, A26, A27
Projet structurant	7	A02, A06, A10, A18, A21, A23, A24
Complément	4	A09, A12, A13, A28
À arbitrer	0	

Feuille de route

Vague	Période	Objectif	Actions
1. Fermer les portes ouvertes	M1 à M3	Supprimer les causes directes des risques G4 et poser la gouvernance	A01, A03, A04, A05, A09, A11, A12, A14, A16, A20, A26, A28
2. Construire les défenses	M4 à M9	Détection, authentification des utilisateurs, chiffrement, continuité, tiers	A06, A07, A08, A10, A13, A15, A17, A18, A19, A21, A22, A23, A24, A25, A27
3. Faire reconnaître	M10 à M18	Audits de certification ISO 27001 et HDS activité 5	A02 (lancée dès M1)

Justification des choix (arguments d'entretien)

Choix	Justification
A05 et A11 en tout premier	Ce sont les deux mesures qui cassent le scénario de rançongiciel (R01) pour un effort faible : sans compte d'administration compromis, pas de prise de contrôle ; avec des sauvegardes hors d'atteinte, pas de perte définitive
La certification en dernier	Un certificat constate un système qui fonctionne. Le viser d'abord produit de la documentation sans réduire les risques
A03 en gain rapide	La décision coûte peu, mais elle conditionne l'architecture, les contrats et le budget de tout le reste
Aucune action « à arbitrer »	Les actions à faible impact et fort effort ont été écartées lors de la construction du plan (par exemple un SOC interne en 24/7)
Impact et effort notés sur 4	Échelle paire : elle interdit la note médiane de confort
Indicateur pour chaque action	Une action sans critère de fin ne se termine jamais ; c'est aussi l'exigence d'évaluation de l'efficacité (ISO 27001 clause 9.1, NIS2 art. 21.2.f)

7. Politique de sécurité des systèmes d'information (version courte)

Organisme	Télémédix SAS (cas fictif)
Version	1.0, projet soumis à l'approbation de la direction générale
Diffusion	Tous les salariés ; extrait communicable aux clients
Révision	Annuelle, et après tout incident majeur ou changement de périmètre

1. Objet et engagement de la direction

Télémédix traite, pour le compte de professionnels de santé, les données de santé de leurs patients. Leur confiance et le secret médical sont la condition d'existence de l'entreprise. La direction générale s'engage à protéger ces données, à attribuer les moyens nécessaires, à respecter les obligations légales (RGPD, code de la santé publique, référentiels de l'ANS) et à améliorer la sécurité de façon continue. Elle approuve cette politique, les risques résiduels et le plan d'actions.

2. Périmètre

La politique s'applique à la plateforme Télémédix, aux activités de développement, d'exploitation et de support, à tous les salariés, stagiaires et prestataires, ainsi qu'aux fournisseurs qui interviennent sur ces activités.

3. Objectifs de sécurité

Objectif	Cible mesurable
Confidentialité des données de santé	Aucun accès non autorisé ; tout accès du personnel à un dossier est justifié et tracé
Intégrité des dossiers et des ordonnances	Toute modification est imputable à un utilisateur authentifié à deux facteurs
Disponibilité du service	Disponibilité mensuelle de 99,9 % aux heures ouvrées ; reprise en 4 heures ; perte de données maximale d'une heure
Traçabilité	Traces d'accès conservées 12 mois et protégées contre la modification
Conformité	Certifications ISO 27001 et HDS (activité 5) obtenues sous 18 mois

4. Organisation

Rôle	Responsabilités
Direction générale	Approuve la politique, arbitre les moyens, accepte les risques résiduels, préside la cellule de crise
RSSI	Pilote le système de management de la sécurité, l'analyse de risques et le plan d'actions ; rend compte directement au directeur général
DPO	Conseille et contrôle la conformité au RGPD ; est associé à tout projet traitant des données personnelles
Responsables d'équipe	Appliquent la politique dans leur périmètre ; valident les habilitations de leurs collaborateurs
Chaque collaborateur	Respecte les règles, protège ses moyens d'authentification, signale tout événement suspect
Comité sécurité (trimestriel)	Suit les risques, les incidents, les indicateurs et l'avancement du plan

5. Règles de sécurité

1. **Analyse de risques.** Une analyse EBIOS RM est tenue à jour ; tout projet ou changement majeur fait l'objet d'une analyse de risques et, si nécessaire, d'une AIPD avant sa mise en production.
2. **Accès.** Les droits sont accordés selon le besoin d'en connaître et le moindre privilège, sur comptes nominatifs, et revus chaque trimestre. Ils sont retirés le jour du départ.
3. **Authentification.** L'authentification à plusieurs facteurs est obligatoire pour tout accès d'administration et pour tout accès à des données de santé. Les secrets ne sont jamais partagés ni stockés en clair.
4. **Accès aux données de santé par le personnel.** Il est interdit par défaut. Il n'est possible que pour résoudre un incident, avec justification, durée limitée, trace et revue.
5. **Chiffrement.** Les données de santé sont chiffrées en transit et au repos ; les clés sont gérées séparément des données.
6. **Minimisation.** Aucune donnée de santé ne figure dans les notifications, les tickets, les journaux ou les environnements de test. Les consultations ne sont pas enregistrées.
7. **Développement.** Chaque modification est revue par un pair et passe les contrôles automatiques de sécurité ; les environnements sont séparés ; un test d'intrusion est réalisé chaque année.
8. **Exploitation.** Les systèmes sont inventoriés, durcis, cloisonnés et corrigés dans des délais définis ; l'administration passe par un bastion et des postes dédiés.
9. **Sauvegarde et continuité.** Les sauvegardes sont isolées de la production, immuables et testées chaque trimestre ; le plan de reprise est testé chaque année.
10. **Journalisation et détection.** Les accès et les actions d'administration sont journalisés, centralisés et surveillés.
11. **Fournisseurs.** Les données de santé ne sont confiées qu'à des hébergeurs certifiés HDS, dans l'Espace économique européen ; chaque fournisseur critique est évalué chaque année et lié par des clauses de sécurité.
12. **Postes et mobilité.** Les postes sont chiffrés, protégés et gérés par l'entreprise ; l'usage de matériels personnels pour accéder à la production est interdit.

6. Gestion des incidents

Tout événement suspect est signalé sans délai au RSSI (adresse et numéro d'astreinte dédiés). Le RSSI qualifie l'incident, déclenche si besoin la cellule de crise et tient un journal. En cas de violation de données, les clients responsables de traitement sont informés sans délai ; les notifications réglementaires (CNIL sous 72 heures, autres autorités selon les textes applicables) sont préparées avec le DPO. Chaque incident fait l'objet d'un retour d'expérience.

7. Sensibilisation

Chaque collaborateur est formé à son arrivée puis chaque année. Les administrateurs, les développeurs et le support suivent une formation adaptée à leur métier. Les dirigeants sont formés à la gestion du risque cyber.

8. Contrôle et conformité

L'application de la politique est vérifiée par des indicateurs trimestriels, un audit interne annuel et une revue de direction annuelle. Les dérogations sont écrites, limitées dans le temps et validées par le RSSI ; celles qui touchent les données de santé le sont par la direction générale.

9. Manquements

Le non-respect de cette politique peut entraîner des mesures disciplinaires prévues par le règlement intérieur, sans préjudice des poursuites pour violation du secret professionnel.

Approbation : direction générale, date et signature.

Annexe : points à vérifier et sources

Ce dossier est un exercice sur un cas fictif. Il ne constitue ni un avis juridique ni un audit. Les points ci-dessous doivent être contrôlés sur les textes officiels avant toute présentation.

A. Points à vérifier

Confiance : **forte** (fait établi et recoupé), **moyenne** (raisonnement défendable, à confirmer), **faible** (hypothèse de travail).

#	Sujet	Ce que le dossier affirme	Confiance	Où vérifier
1	Transposition de NIS2	Loi non promulguée au 11/11/2026 ; examen à l'Assemblée du 9 au 13 novembre 2026	Forte à la date indiquée, périssable	Dossier législatif sur assemblee-nationale.fr ; Légifrance ; cyber.gouv.fr
2	Qualification NIS2 d'un éditeur SaaS	Probable « fournisseur de services d'informatique en nuage », donc entité importante à 52 salariés	Moyenne	Directive (UE) 2022/2555 : art. 2, 3, 6 et annexe I ; loi française promulguée et décrets ; outil d'auto-qualification de l'ANSSI
3	Seuils de taille	Petite entreprise : moins de 50 personnes et chiffre d'affaires ou bilan ≤ 10 M€	Forte	Recommandation 2003/361/CE ; prise en compte des entreprises liées
4	Règlement d'exécution (UE) 2024/2690	S'applique aux fournisseurs de services numériques, dont l'informatique en nuage	Moyenne	EUR-Lex ; articulation avec le référentiel de l'ANSSI
5	Référentiel Cyber France (ReCyF)	Publié par l'ANSSI le 17 mars 2026 en document de travail	Moyenne (sources secondaires)	cyber.gouv.fr
6	Activités HDS	Six activités ; chaque acteur est certifié pour celles qu'il réalise	Forte	Code de la santé publique, art. L.1111-8 et R.1111-9 ; référentiel de certification HDS v2
7	Activité 5 pour un éditeur qui administre ses VM	L'éditeur doit être certifié	Moyenne	FAQ de l'ANS sur l'activité 5 ; travaux pédagogiques de l'ANS (sessions d'octobre et novembre 2026) ; avis juridique
8	Activité 4	Sans objet quand l'éditeur exploite sa propre plateforme sur des VM	Faible	Référentiel HDS v2, chapitre sur le périmètre
9	Référentiel HDS v2	Publié en 2024 ; seule version valide depuis le 16 mai 2026 ; exigences de localisation dans l'EEE et de transparence sur les accès hors UE	Forte	esante.gouv.fr ; arrêté de publication au Journal officiel
10	Numéros d'exigence HDS	Non cités dans le dossier	Sans objet	À reporter depuis le référentiel officiel ; une révision v2.1 est en concertation

#	Sujet	Ce que le dossier affirme	Confiance	Où vérifier
11	Prestataire visio et HDS	Un flux en transit non conservé ne constitue pas un hébergement	Faible	FAQ de l'ANS ; avis juridique
12	Rôles RGPD	Clients responsables de traitement, éditeur sous-traitant ; éditeur responsable pour le compte patient	Moyenne	Lignes directrices 07/2020 du CEPD ; guide du sous-traitant de la CNIL ; DPO
13	AIPD obligatoire	Oui (santé, grande échelle, personnes vulnérables)	Forte	Liste de la CNIL des traitements soumis à AIPD ; lignes directrices WP 248
14	Base légale	Art. 6.1.b, c ou e et art. 9.2.h ; pas le consentement	Forte	RGPD ; référentiel de la CNIL pour les cabinets médicaux
15	Consentement à l'acte de télémédecine	Prévu par le code de la santé publique, distinct du consentement RGPD	Moyenne	Code de la santé publique, art. R.6316-2
16	Durée de conservation du dossier	20 ans ; 28e anniversaire pour un mineur ; 10 ans après le décès	Forte pour les établissements ; recommandation en libéral	Code de la santé publique, art. R.1112-7 ; Conseil national de l'Ordre des médecins ; référentiels de la CNIL
17	Durée des journaux	6 mois à 1 an	Moyenne	Recommandation de la CNIL sur la journalisation ; PGSSI-S (traces d'accès aux données de santé)
18	Données de paiement	13 mois ; pièces comptables 10 ans	Moyenne	Recommandation de la CNIL sur les données de carte ; code de commerce
19	Identifiant national de santé	Usage limité au référencement des données de santé ; obtenu par le téléservice INSi	Moyenne	Référentiel INS (ANS)
20	Référentiel des SI de téléconsultation	Opposable ; certificat de conformité délivré par l'ANS ; calendrier d'extension à tous les éditeurs incertain	Moyenne	esante.gouv.fr ; arrêté du 9 février 2024
21	Intitulés de l'Annexe A	93 mesures (37, 8, 14, 34) ; titres français usuels	Forte pour la structure, moyenne pour la lettre des titres	NF EN ISO/IEC 27001:2022 (AFNOR)
22	Formule du niveau de menace	(dépendance × pénétration) / (maturité × confiance)	Forte	Guide EBIOS Risk Manager de l'ANSSI, atelier 3
23	Délais de notification NIS2	24 heures, 72 heures, un mois	Forte	Directive, art. 23

B. Sources consultées (novembre 2026)

Transposition de NIS2

- Le Monde Informatique, « NIS 2 : la loi Résilience arrive enfin à l'Assemblée », 10 novembre 2026 : https://www.lemondeinformatique.fr/cybersecurite-conformite/nis-2-la-loi-resilience-arrive-enfin-a-l-assemblee

- InformatiqueNews, « NIS 2 : ce que la loi Résilience change pour les DSI, RSSI et dirigeants », novembre 2026 : https://www.informatiquenews.fr/nis2-loi-resilience-obligations-entreprises-251585
- Leto, « Transposition NIS 2 : examen à l'Assemblée le 9 novembre 2026 » : https://www.leto.legal/news/nis-2-projet-loi-resilience-assemblee-nationale-9-novembre-2026
- Phinasoft, « Loi résilience : où en est la transposition de NIS 2 en France ? », 8 octobre 2026 : https://phinasoft.com/fr/blog/loi-resilience-transposition-nis-2-france/

HDS

- ANS, communiqué du 16 mai 2024 sur la publication du référentiel HDS : https://esante.gouv.fr/index%2ephp/espace-presse/publication-au-journal-officiel-du-referentiel-de-certification-hds-souverainete-des-donnees-et-ameliorations-du-referentiel
- ANS, webinaire HDS du 15 octobre 2025 (transition v2, activité 5) : https://industriels.esante.gouv.fr/sites/default/files/media/document/Webinaire-HDS_20251015_vf.pdf
- ANS, session collective HDS du 7 octobre 2026 : https://esante.gouv.fr/sites/default/files/media/document/20261007_ANS_SessionCollective_HDS%20v1.0.pdf
- ANS, travaux pédagogiques sur l'activité 5, session du 4 novembre 2026 : https://esante.gouv.fr/sites/default/files/media/document/20261104_ANS_SessionCollective_HDS%20v0.7.pdf
- ANS, page HDS : https://esante.gouv.fr/produits-services/hds

Téléconsultation

- ANS, « Le référentiel d'interopérabilité, de sécurité et d'éthique des SI de téléconsultation désormais opposable », 14 février 2024 : https://esante.gouv.fr/actualites/toutes-les-actualites/le-referentiel-d-interoperabilite-de-securite-et-d-ethique-des-systemes-d-informations-de
- HAS, référentiel de bonnes pratiques applicable aux sociétés de téléconsultation : https://has-sante.fr/jcms/p_3470126/fr/teleconsultation-referentiel-de-bonnes-pratiques-professionnelles-applicable-aux-societes-de-teleconsultation

Protection des données

- Conseil national de l'Ordre des médecins, FAQ sur la protection des données (durées de conservation) : https://www.conseil-national.medecin.fr/medecin/exercice/protection-donnees-faq

C. Textes de référence à consulter à la source

Texte	Éditeur
Guide EBIOS Risk Manager et fiches méthodes	ANSSI (cyber.gouv.fr)
Guide d'hygiène informatique	ANSSI
Directive (UE) 2022/2555 et règlement d'exécution (UE) 2024/2690	EUR-Lex
Règlement (UE) 2016/679 (RGPD)	EUR-Lex

Texte	Éditeur
Guides AIPD, guide du sous-traitant, guide de la sécurité des données personnelles	CNIL (cnil.fr)
Référentiel de certification HDS, PGSSI-S, référentiel INS, Pro Santé Connect	ANS (esante.gouv.fr)
Code de la santé publique	Légifrance
ISO/IEC 27001:2022 et 27002:2022	ISO, AFNOR